

Chapter 4

Footprinting and Reconnaissance

THE FOLLOWING CEH EXAM TOPICS ARE COVERED IN THIS CHAPTER:

- ✓ **Technical assessment methods**
 - ✓ **Port scanning**
 - ✓ **Privacy and confidentiality**
 - ✓ **Data analysis**
 - ✓ **Vulnerability scanning**
-

It's commonly believed that attackers do a lot of work up front before launching attacks. They get a sense of how large the attack surface is and where their targets are. This can take a lot of work, using a lot of different tool and skill sets. The process of getting the size and scope of the target is called *footprinting*—in other words, the attacker, or you, the ethical hacker, is trying to pick up the footprint of the target organization. When it comes to ethical hacking, you may have some help from the target, who would have employed you for your services. They may provide you with some footholds to get a sense of the scope and scale of what you should be doing. It's possible, though, that you are starting blind and you have to get your own footholds.

There are a lot of places you, as an ethical hacker, can get information about your targets, though. Open source intelligence is the term that describes identifying information about your target using freely available sources. There are other places where you can acquire information in other than legal ways, and of course, you could directly infiltrate a company's physical locations to get some information that you can use against your target. That's potentially illegal and definitely not open source.

The objective here is to acquire data that you need without tipping off your target that you are doing it. This is why you might use third-party sources to acquire the information you need. You can also gather a lot of details by interacting with services at the target in ways that would be expected. As an example, you might visit their website requesting pages, just as any other visitor to their site might do. Nothing special about what

you are asking for or how you are asking for it. However, if you know where to look, you can gather a lot of information about systems and technology in use by your target.

One source of a lot of detail about your target is the Domain Name System (DNS). This isn't something a lot of people spend time thinking about. When it works, you have no idea because it happens quietly in the background. However, there is a lot of data stored in DNS servers about domains and even IP address blocks. This data can be mined, and you can get a better understanding about your target and systems and the IP address blocks that may be associated with your target.

It may be useful as you work through the different stages of a testing methodology to identify matches to the MITRE ATT&CK framework. We're in luck on this phase. The ATT&CK framework has a reconnaissance phase, and it covers scanning as well as gathering information from different sources about different aspects of the target. While it's common to think that attackers are looking for vulnerabilities and systems of interest, they are probably more likely to look for human targets. This may be identifying employees and email addresses but also, perhaps just as important, knowing what those employees do, which will tell the attacker how much access they have. More access means an attacker may be able to get to something that can easily be monetized.

Over the course of this chapter, we'll go over sources of information about your target as well as the tools you would use to gather that information. While much of it is quiet and there is at least one tool that is entirely passive, there is some active investigation as well. The first place to start, though, is how to use open sources of data to identify a jumping-off point for getting information about your target.

Open Source Intelligence

There are a couple of reasons you may want to use open source intelligence. The first is that you haven't been provided with any details about your target. You may be doing a true red team against the target company and systems. In that case, you need to locate as much information as you can so you know not only what your attack surface looks like but possible ways in. Additionally, you can find a lot of information about individuals within an organization. This is especially useful because social engineering attacks have a good possibility of success. Having contacts to go after is essential.

The second reason is that organizations aren't always aware of the amount of information they are leaking. As noted earlier, attackers can find footholds, as well as potential human targets for social engineering attacks. If you are working hand in hand with the company you are performing testing for (that is, you are doing white-box testing), you don't need to use open source intelligence for starting points, but you should still gather what information is available for the awareness of the company. They may be able to limit their exposure. Even if there isn't anything that could be pulled back, they could work on awareness so employ-

ees and the organization as a whole aren't leaking information unnecessarily.

There are a number of tools that can be used to automate the collection of information, and we'll cover their use as part of looking at how to gather open source intelligence about companies and people. We'll also take a look at social networking sites and some of the ways those websites can be used. Even in cases where privacy settings are locked down, there is still a lot of information that can be gathered. There are also sites that exist to be public, and those can definitely be used.

Companies

There are several starting points when it comes to acquiring open source intelligence about your target. The first is to look at the company overall. You'll want to gather information about locations the company has. There are instances where this can be easy. However, increasingly, it can be harder. The reason it can be harder is that companies recognize that the more information they provide, the more that information can be used against them. So, unless they are required to provide that information by regulations, they don't provide it. There are a few resources that can be used to gather information about companies.

Sometimes, these resources can be used to gather information that may be used for social engineering attacks. In some cases, you will be able to gather details about a company's network. Both types of information can be useful. Details about a company and its organizational and governance structure can come from a database maintained by the U.S. government, in the case of businesses registered in the U.S. Details about the business network may come from databases maintained by the organizations that are responsible for governance of the Internet.

EDGAR

Public companies are required to provide information about themselves. There are resources you can use to look up that information. In the process, you may gather information about a company's organizational structure. The organizational structure can tell you who has what position, so when you are working on sending out email messages to gather additional information later, you know who they should appear to be from. You can select the holder of an appropriate position.

The Securities and Exchange Commission (SEC) has a database that stores all public filings associated with a company. The Electronic Data Gathering, Analysis, and Retrieval (EDGAR) system can be used to look up public filings such as the annual report in the form 10-K. Additionally, the quarterly reports, 10-Qs, are also submitted to EDGAR and stored there. These reports provide details about a company's finances. The 11-K, a form including details about employee stock option plans, is also filed with EDGAR. Accessing EDGAR is as easy as going to EDGAR at the SEC website. You can see the search field, part of the page, in [Figure 4.1](#).

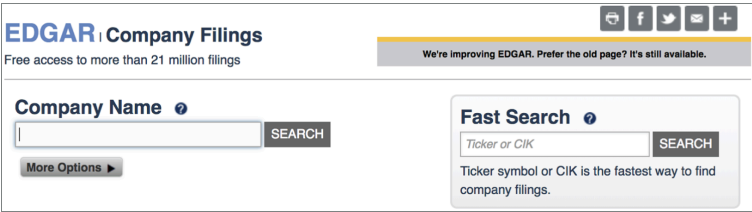


FIGURE 4.1 EDGAR site

One of the most useful forms you can find in EDGAR is Schedule 14A on SEC site, which is a proxy statement and will include the annual report to the shareholders, which may include a lot of useful information for you. As an example, Figure 4.2 shows a very small section of the annual report to the shareholders for Microsoft Corporation. Other sections that are not shown include Corporate Governance at Microsoft, Board of Directors, and Audit Committee Matters. While at a high level—what is included in these reports will be the same across all public companies—there may be some companies that present more in the way of specific details than other companies. Some companies will have more to report than others. For instance, the table of contents for the Microsoft report shows the page total in the 80s. The report for John Wiley & Sons shows a page count in the 50s. That’s about 30 fewer pages between the two companies.

3

Named executive officer compensation

Proposal 2: Advisory vote to approve named executive officer compensation
Statement in support
Compensation discussion and analysis
Section 1 – Executive compensation overview
Shareholder feedback considered in evolution of pay program
Annual compensation components
Section 2 – Fiscal year 2017 compensation decisions
Business results
Decisions
Fiscal year 2017 base salaries
Cash incentive awards
Fiscal year 2017 stock awards
Section 3 – Fiscal year 2017 compensation design process
Executive compensation program design
Target annual compensation mix
Paying competitively
Technology labor market
Scope of executive roles
Establishing compensation opportunities
Independent compensation consultant
Section 4 – Other compensation policies and information
No significant executive benefits and perquisites
Limited post-employment compensation
Strong clawback policy
Robust stock ownership policy
Derivatives trading, hedging, and pledging prohibited
Deductibility of executive compensation
Annual compensation risk assessment
Compensation Committee report
Fiscal year 2017 compensation tables
Summary compensation table
Grants of plan-based awards
Outstanding equity awards at June 30, 2017
Stock vested
Non-qualified deferred compensation
Equity compensation plan information
Compensation Committee interlocks and insider participation
Stock ownership information
Principal shareholders
Section 16(a) – beneficial ownership reporting compliance
Proposal 3: Advisory vote on frequency of advisory vote on executive compensation

31
31
32
33
33
34
38
38
38
38
38
38
42
43
43
44
44
45
45
45
46
46
46
46
46
47
48
48
48
49
50
50
50
52
53
54
54
55
55
55
57
57
57

2017 PROXY STATEMENT
viii

FIGURE 4.2 Portion of Schedule 14A for Microsoft

Domain Registrars

EDGAR is only for public companies. Not every company is public. You don't get the same level of insight for a private company that you do for a public company. However, EDGAR is not the only resource that can be used to gather information about a company. Another source of information, related to the Internet itself, is the domain registrars. You won't get the same sort of information from the domain registrars as you would from EDGAR, but it's still sometimes a decent source of information. For a

start, you can get the address of what is probably the company's headquarters.

This is not a guarantee, however. As mentioned, companies are starting to hide information provided to the registrars. Information is hidden behind the registrar. When you ask for information, you will get what the registrar has been asked to present and not necessarily the real details. There is nothing that says that the registrars have to be provided with real addresses, unless they are checking a billing address on a credit card for payment. In fact, there have been times I have had domains registered with bogus phone numbers and incorrect addresses. Since the data is public, it's important to be careful about what is shared. Anyone can mine the registries for this information and use it for any number of purposes.

Before we get too far down this road, though, it's probably useful for you to understand how the Internet is governed when it comes to domains and addresses. First, there is the Internet Corporation for Assigned Names and Numbers (ICANN). Underneath ICANN is the Internet Assigned Numbers Authority (IANA), which is responsible for managing IP addresses, ports, protocols, and other essential numbers associated with the functioning of the Internet. Prior to the establishment of ICANN in 1998, IANA's functions were managed by one man, Jon Postel, who also maintained the request for comments (RFC) documents.

In addition to ICANN, responsible for names and numbering, are the domain registrars. These organizations store information about addresses they are responsible for as well as contacts. There was a time when registering a domain and other data went through a single entity. Now, though, there are several companies that can perform registrant functions. If you want to register a domain, you go to a registrar company like DomainMonger or GoDaddy. Those companies can then be queried for details about the domains.

To grab information out of the regional Internet registry (RIR), you would use the `whois` program. This is a program that can be used on the command line on most Unix-like systems, including Linux and macOS. There are also websites that have implementations of `whois` if you don't have a Unix-like system handy. Here you can see a portion of the output from a `whois` query.

`whois` Query of wiley.com

```
$ whois wiley.com
Domain Name: WILEY.COM
Registry Domain ID: 936038_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.corporatedomains.com
Registrar URL: http://cscdbs.com
Updated Date: 2021-08-30T16:27:21Z
Creation Date: 1994-10-12T04:00:00Z
Registry Expiry Date: 2023-10-11T04:00:00Z
Registrar: CSC Corporate Domains, Inc.
Registrar IANA ID: 299
```

```
Registrar Abuse Contact Email: domainabuse@cscglobal.com
Registrar Abuse Contact Phone: 8887802723
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: AUS-IBEXTDNS-01.WILEY.COM
Name Server: CAR-IBEXTDNS-01.WILEY.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
←- SNIP →
Domain Name: wiley.com
Registry Domain ID: 936038_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.corporatedomains.com
Registrar URL: www.cscprotectsbrands.com
Updated Date: 2021-08-30T12:27:21Z
Creation Date: 1994-10-12T00:00:00Z
Registrar Registration Expiration Date: 2023-10-11T04:00:00Z
Registrar: CSC CORPORATE DOMAINS, INC.
Sponsoring Registrar IANA ID: 299
Registrar Abuse Contact Email: domainabuse@cscglobal.com
Registrar Abuse Contact Phone: +1.8887802723
Domain Status: clientTransferProhibited http://www.icann.org/epp#clientTransferProhibited
Registry Registrant ID:
Registrant Name: Domain Administrator
Registrant Organization: John Wiley & Sons, Inc
Registrant Street: 111 River Street
Registrant City: Hoboken
Registrant State/Province: NJ
Registrant Postal Code: 07030
Registrant Country: US
Registrant Phone: +1.3175723355
Registrant Phone Ext:
Registrant Fax: +1.3175724355
Registrant Fax Ext:
Registrant Email: domains@wiley.com
Registry Admin ID:
Admin Name: Domain Administrator
Admin Organization: John Wiley & Sons, Inc
Admin Street: 111 River Street
Admin City: Hoboken
Admin State/Province: NJ
Admin Postal Code: 07030
Admin Country: US
Admin Phone: +1.3175723355
Admin Phone Ext:
Admin Fax: +1.3175724355
Admin Fax Ext:
Admin Email: domains@wiley.com
Registry Tech ID:
Tech Name: Electronic Support Services
Tech Organization: John Wiley & Sons Inc
Tech Street: 111 River Street
Tech City: Hoboken
Tech State/Province: NJ
Tech Postal Code: 07030
Tech Country: US
Tech Phone: +1.3175723100
Tech Phone Ext:
Tech Fax: +1.3175724355
Tech Fax Ext:
Tech Email: domains@wiley.com
Name Server: car-ibextdns-01.wiley.com
```

```
Name Server: aus-ibextdns-01.wiley.com
```

DNSSEC: unsigned There is a lot of output there to look through, and I've snipped out a bunch of it to keep it to really relevant information. First, `whois` checks with IANA's `whois` server to figure out who it needs to check with about this specific domain. You can see that happen at the very top of the output. IANA indicates that CSC Corporate Domains is the registrar for this domain. We get the details about the registrar CSC Corporate Domains. After that, and a lot of information being snipped out, we finally get the details about the domain wiley.com. What you can see in the output is the address and phone number for the company. Additionally, you get information about a handful of contacts for the company. Registrars expect an administrative contact and a technical contact.

As indicated earlier, not all domains will provide this level of detail. An example of a domain that doesn't include any contact details is spamhaus.org. Here you can see that the contact information shows that the data has been redacted for privacy.

Details About spamhaus.org

```
Domain Name: spamhaus.org
Registry Domain ID: 3438c67fd16d45eca26608d562bb3be6-LROR
Registrar WHOIS Server: http://whois.comlaude.com
Registrar URL: https://comlaude.com/whois
Updated Date: 2022-09-06T23:10:56Z
Creation Date: 1999-10-01T11:03:57Z
Registry Expiry Date: 2023-10-01T11:03:57Z
Registrar: Nom-iq Ltd. dba COM LAUDE
Registrar IANA ID: 470
Registrar Abuse Contact Email: abuse@comlaude.com
Registrar Abuse Contact Phone: +44.2074218250
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: serverDeleteProhibited https://icann.org/epp#serverDeleteProhibited
Domain Status: serverTransferProhibited https://icann.org/epp#serverTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Domain Status: serverUpdateProhibited https://icann.org/epp#serverUpdateProhibited
Registry Registrant ID: REDACTED FOR PRIVACY
Registrant Name: REDACTED FOR PRIVACY
Registrant Organization: Spamhaus IP Holdings SLU
Registrant Street: REDACTED FOR PRIVACY
Registrant City: REDACTED FOR PRIVACY
Registrant State/Province:
Registrant Postal Code: REDACTED FOR PRIVACY
Registrant Country: AD
Registrant Phone: REDACTED FOR PRIVACY
Registrant Phone Ext: REDACTED FOR PRIVACY
Registrant Fax: REDACTED FOR PRIVACY
Registrant Fax Ext: REDACTED FOR PRIVACY
```

Using a strategy like this will keep information private and out of the hands of the very people spamhaus.org seeks to protect against. The data provided can be used to create a mailing list for spammers. It can also be

used to create a physical mailing list for traditional junk mail providers (sometimes called *mail marketing companies*).

Regional Internet Registries

Not all the useful information is stored with the domain registrars, however. There is other data that is important to be kept. Earlier, we discussed IANA. While the IANA server provided information about domain registrars, its purpose has long been to be a central clearinghouse for addresses. This includes not only port numbers for well-known services but also IP addresses. IANA, at a high level, owns all IP addresses. It hands out those IP addresses, based on need, to the RIRs. The RIRs then hand them out to organizations that fall into their geographic region.

There are five RIRs around the world. They are based in different geographic regions, and an organization would refer to the RIR where they are located for things like IP addresses. The RIRs and the geographic areas they are responsible for are listed here:

- **African Network Information Center (AfriNIC)** Africa
- **American Registry for Internet Numbers (ARIN)** United States and Canada, as well as Antarctica and parts of the Caribbean
- **Asia Pacific Network Information Centre (APNIC)** Asia, Australia, New Zealand, and neighboring countries
- **Latin America and Caribbean Network Information Centre (LACNIC)** Latin America and parts of the Caribbean
- **Réseaux IP Européens Network Coordination Centre (RIPE NCC)** Europe, Russia, Greenland, the Middle East, and parts of Central Asia

All of these RIRs have their own databases that can be queried using `whois`, just as we used `whois` to query information from the domain registrars. Typically, you would use `whois` against the RIRs to find out who owns a particular IP address. For example, in the output for [wiley.com](#) earlier, part of the output indicated which name servers the domain uses to resolve hostnames to IP addresses. One of those name servers is [car-ibextdns-01.wiley.com](#). With a minimal amount of effort (we will cover DNS in the section “Domain Name System” later in this chapter), we can discover that the hostname [car-ibextdns-01.wiley.com](#) resolves to the IP address 63.97.119.2. Using `whois`, we can find out who owns that IP address. You can see the results of that query in the following code.

`whois` Query for IP Address

```
$ whois 63.97.119.2

#
# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy_reporting/
#
# Copyright 1997-2023, American Registry for Internet Numbers, Ltd.
```



```
#

# start

NetRange:      63.64.0.0 - 63.127.255.255
CIDR:          63.64.0.0/10
NetName:       UUNET63
NetHandle:     NET-63-64-0-0-1
Parent:        NET63 (NET-63-0-0-0-0)
NetType:       Direct Allocation
OriginAS:
Organization:  Verizon Business (MCICS)
RegDate:       1999-01-22
Updated:       2022-05-31
Comment:       ADDRESSES WITHIN THIS BLOCK ARE NON-PORTABLE
Ref:           https://rdap.arin.net/registry/ip/63.64.0.0

OrgName:       Verizon Business
OrgId:         MCICS
Address:       22001 Loudoun County Pkwy
City:          Ashburn
StateProv:     VA
PostalCode:    20147
Country:       US
RegDate:       2006-05-30
Updated:       2022-10-11
Ref:           https://rdap.arin.net/registry/entity/MCICS

<snip>

NetRange:      63.97.118.0 - 63.97.119.255
CIDR:          63.97.118.0/23
NetName:       UU-63-97-118
NetHandle:     NET-63-97-118-0-1
Parent:        UUNET63 (NET-63-64-0-0-1)
NetType:       Reassigned
OriginAS:
Customer:      JOHN WILEY & SONS, INC. (C06398648)
RegDate:       2017-03-21
Updated:       2017-03-21
Comment:       Addresses within this block are non-portable.
Ref:           https://rdap.arin.net/registry/ip/63.97.118.0

CustName:      JOHN WILEY & SONS, INC.
Address:       1649 W FRANKFORD RD
City:          CARROLLTON
StateProv:     TX
PostalCode:    75007
Country:       US
RegDate:       2017-03-21
Updated:       2017-03-21
Ref:           https://rdap.arin.net/registry/entity/C06398648
```

This provides us with a lot of useful information. First, even though we provided a single IP address, addresses are allocated in blocks. The first thing we find is that the parent block was allocated in 1999. Based on the name of the block, Verizon Business was not the original owner, since it is named UUNET63 and UUNET is a network that Verizon obtained through acquisition in the early 2000s. The specific block the IP address provided belongs to, though, is 63.197.118.0 – 63.197.119.255. That block, unsurprisingly, belongs to John Wiley & Sons. You can see that the address for John Wiley & Sons is in Carrollton, TX, which aligns with the block being registered under ARIN, which shows as the `whois` server used in the first part of the output. The business is located in the United States, so the corresponding regional registry is ARIN.

We've learned a couple of things about the business and the IP addresses that belong to it. Additionally, you can see we have a contact that came out of the response. This gives us a name and email address. If we were going to be testing against this business, we could make use of this information.

People

While systems and the IP addresses associated with them make good entry points for technical attacks—those against services that are available—contact information for people can be more useful. There are other places we can go to get lists of people who belong to a target organization. Again, there are utilities we can use to help us gather this information. One of them is theHarvester. This is a script that will search through different sources to locate contact information based on a domain name provided to the program. In the following code, you can see the output from theHarvester run against the domain `wiley.com`, using Bing as the search source. DuckDuckGo is another search option, but it didn't yield any people results in this search, though it did yield a single host.

theHarvester Output

```
$
theHarvester -d wiley.com -b bing
*****
*
*  _ _ _ _ _  \  \  _ _ _ _ _  _ _ _ _ _  _ _ _ _ _  *
* | | | | _ _ _ _ _  \  \  _ _ _ _ _  _ _ _ _ _  _ _ _ _ _  *
* | | | | _ _ _ _ _  \  \  _ _ _ _ _  _ _ _ _ _  _ _ _ _ _  *
* | | | | _ _ _ _ _  \  \  _ _ _ _ _  _ _ _ _ _  _ _ _ _ _  *
* \ _ _ _ _ _  \  \  _ _ _ _ _  \  \  _ _ _ _ _  \  \  _ _ _ _ _  *
*
* theHarvester 4.2.0
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****

[*] Target: wiley.com

Searching 0 results.
```

```
[*] Searching Bing.

[*] No IPs found.

[*] No emails found.

[*] Hosts found: 18
-----
access.wiley.com:63.97.118.255
agupubs.onlinelibrary.wiley.com:162.159.129.87, 162.159.130.87
authorservices.wiley.com:108.138.128.128, 108.138.128.52, 108.138.128.31, 108.138.128.89
bpspsychub.onlinelibrary.wiley.com:162.159.129.87, 162.159.130.87
bpspubs.onlinelibrary.wiley.com:162.159.130.87, 162.159.129.87
car-access.wiley.com:63.97.118.255
careers.wiley.com:34.215.77.72, 52.36.83.75
chemistry-europe.onlinelibrary.wiley.com:162.159.130.87, 162.159.129.87
dev.store.wiley.com:104.18.28.249, 104.18.29.249
ietresearch.onlinelibrary.wiley.com:162.159.129.87, 162.159.130.87
newsroom.wiley.com:162.159.129.11, 162.159.130.11
nph.onlinelibrary.wiley.com:162.159.129.87, 162.159.130.87
onlinelibrary.wiley.com:162.159.130.87, 162.159.129.87
read.wiley.com:104.18.15.106, 104.18.14.106
sid.onlinelibrary.wiley.com:162.159.130.87, 162.159.129.87
support.wiley.com:13.110.24.11, 13.110.24.10, 13.110.24.13
universityservices.wiley.com:23.185.0.2
www.wiley.com:104.18.17.99, 104.18.16.99
```

Bing is not the only source that can be used with theHarvester. Other search sources include VirusTotal, ThreatCrowd, and Yahoo. Many of these require you to register with the service to obtain an application programming interface (API) key so that you can provide it to theHarvester. Without the key, theHarvester can't issue queries to those search services. This helps to protect them against misuse.

HANDS-ON ACTIVITY

You should have a lot of experience running these tools before you try to take the test so get as much time working with them as you can. One example is using theHarvester. Select a domain name you have some association with, preferably one you have some rights to, and use theHarvester to look up information about that domain.

While tools like theHarvester are good for identifying information about people at a company automatically, you may want or need to go deeper. This is where you might consider using a people search website, like Spokeo, BeenVerified, Pipl, Wink, or Intelius. These sites can be used to search for people, though searching for people may cost you money.

There are other people search sites that are more focused on looking at social networking presence, and searches can be done using usernames. The website PeekYou will do people searches using real names. PeekYou also allows you to look for a username instead, though. This username could be found across multiple social network sites, as well as other locations where a username is exposed to the outside world. A search for a

username I have used in the past turned up a few hits, though the information was badly out of date and inconsistent. An online presence, though, can be used for more than just finding people. Searching for me in PeekYou turns up a lot of people who are not me. This is shown in [Figure 4.3](#).

This example should show you that not only can information online be inaccurate but in some (or many) cases, you need to know something about your target before you start looking.

Social Networking

Social networking sites are how people connect. They come in a number of different flavors and have been around for more than two decades, with the first one, [sixdegrees.com](#), launched in 1997. Sites like Myspace have allowed users to share music and personal information with others. Facebook has allowed users to create communities, share news and information, and get back in touch with people they have fallen away from. Twitter is often useful for news and updates, as well as marketing information—making announcements, for example. LinkedIn is useful for all sorts of business purposes. This includes sharing updates about company activities, personal achievements, and moves.

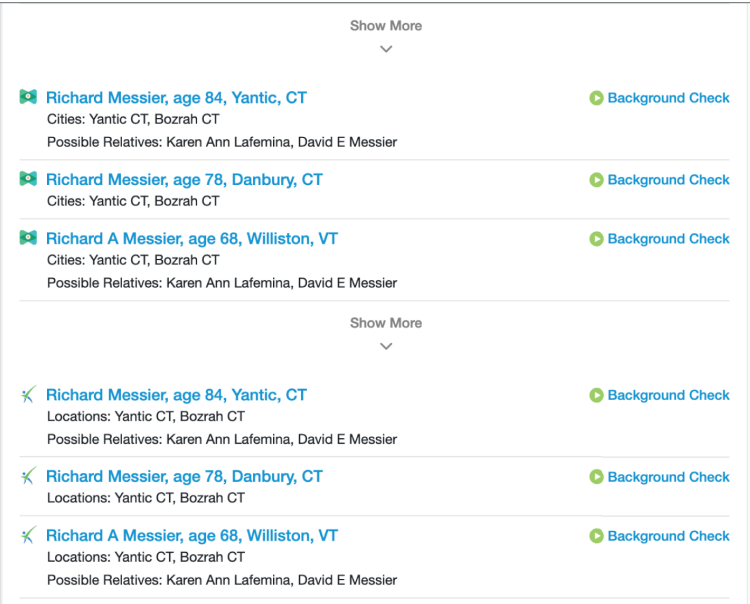


FIGURE 4.3 PeekYou output

You can spend a lot of time looking for information by hand on these sites. There are also tools that you can use. One of them is one we've already looked at. In addition to using traditional search sites like Google and Bing, theHarvester will also search through some of the social network sites. There are also tools that are specific to some of the sites, such as LinkedIn, where you can use CrossLinked. Finally, we have a tool like Maltego, which is good for open source intelligence in general, though there are ways it can be used to search social network sites for details about people and companies.

Facebook

While sites that may primarily be thought of as personal sites may focus more on individuals, they are still useful for someone doing work as an ethical hacker. A site like Facebook is interesting because people seem to let their guard down there, posting a lot of details that perhaps they shouldn't. What they often fail to realize is how much of what they post is searchable. Over time, Facebook has vastly improved how much information can be acquired, though it's still not great. Several years ago, there was a website, www.weknowwhatyouredoing.com, that searched through Facebook posts that would fall into one of four categories—who wants to get fired, who is hungover, who is taking drugs, and who has a new phone number. [Figure 4.4](#) shows some of the posts from the site before it got taken down because the API it used is no longer available.

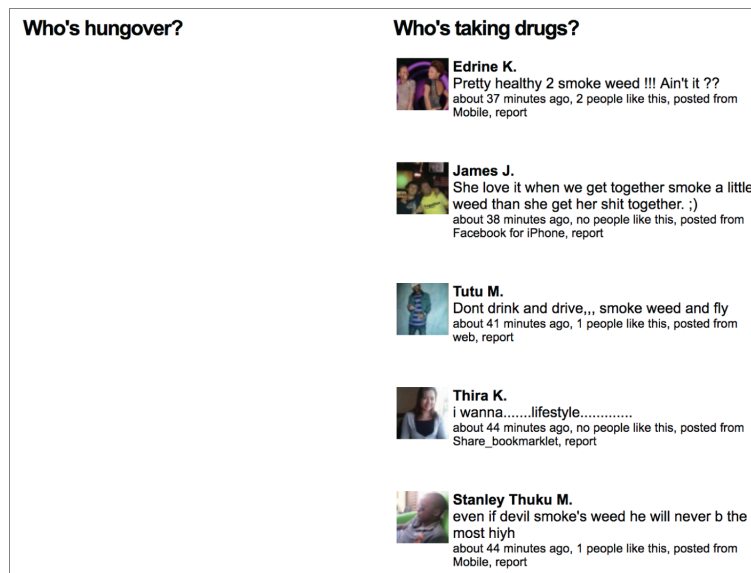


FIGURE 4.4 www.weknowwhatyouredoing.com

This is not to say that Facebook no longer has an API. The Facebook Graph API still exists. It just isn't as open as it once was. There is still a Graph API, and it can still be used in applications. In fact, Facebook provides a Graph API Explorer where queries to the API can be tested. [Figure 4.5](#) shows the Graph API Explorer. Near the top, you can see there is an access token. This token is generated after a number of permissions are selected. The token is based on the user you are logged in as. Once you have a token, you can generate a query. The query shown is the default query, requesting the ID and name for the user. Of course, the name is mine since the access token was based on my login.

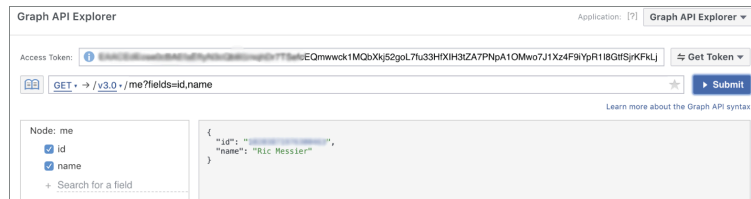


FIGURE 4.5 Facebook Graph API

You don't have to create an application, though, to generate searches. Searches can be done manually. Facebook is not only used by individuals. It is also, often, used by companies. Many companies create their own page where they can post specifics about their products and services. This is another location where you can gather information about the company. [Figure 4.6](#) shows business details about John Wiley & Sons from its own page on Facebook. Besides the information you can see about its location, there are several other categories of information, such as Reviews, Posts, and Community. The reviews can sometimes provide enlightening information, and of course, there is the contact information provided.

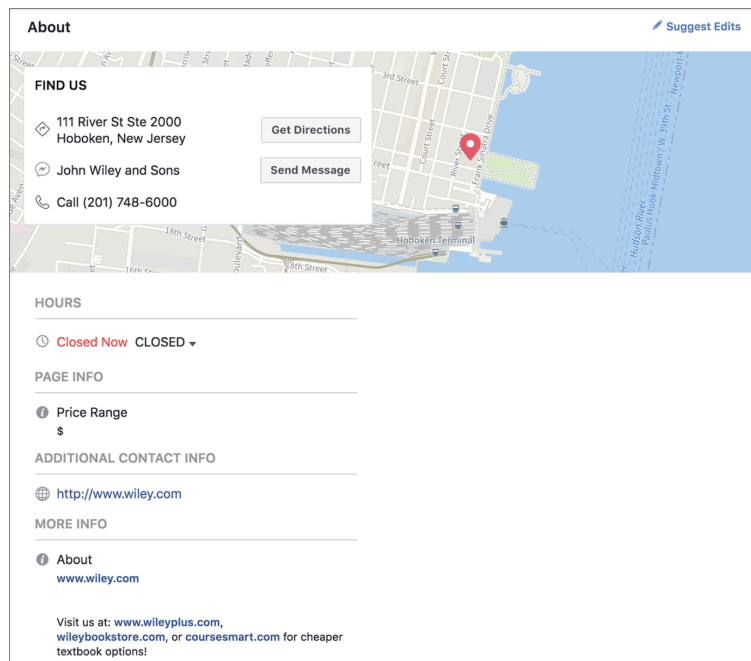


FIGURE 4.6 John Wiley & Sons information

You don't have to rely on just looking up business information on Facebook, though. People regularly post details about their employers on their personal pages. Unfortunately, this is where searching on Facebook can become challenging. You can't, after all, just search for all employees of a particular company using the usual search. However, if you have found some names of employees using other means, you can use those names to find their pages and read their status posts. Often, people will include details of their work situation—companies they do work for and have worked for—as part of their profile. This can help you to better distinguish the employees from other people with the same name.

Much of this relies on how privacy options are set. Often, privacy options are set to public, which means you can probably read the posts of a lot of people you are looking for. You can also likely look at their photos. In an

age of social media and the expectation that you can find out just about anything you want about someone, people often don't think about who can potentially see their posts and photos. This gives us an advantage. However, it isn't always the case that you will be able to see what someone is doing and saying. [Figure 4.7](#) shows the different privacy settings available to Facebook users. One of the challenges with this, though, is that your settings only pertain to what you do. Your settings won't prevent other people from sharing one of your posts or photos, which may allow someone beyond who you would like to see the post or photo. Then it comes down to what their permissions are set to.

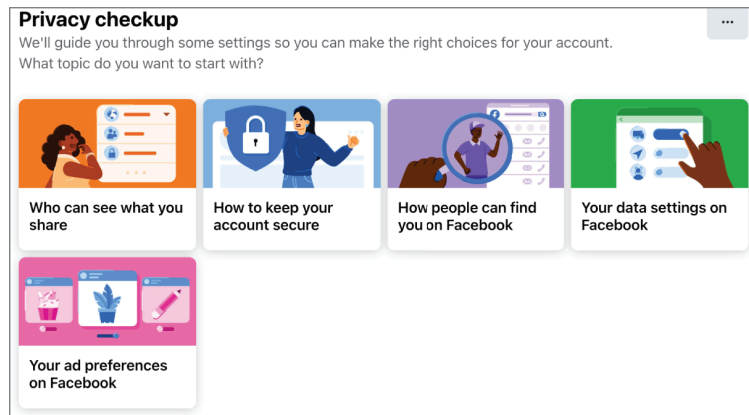


FIGURE 4.7 Facebook permissions settings

Sometimes, people will post a status about their job, including what they may have been doing that day, or they may check in at another job site. Any of this information could potentially be useful to you. However, sites like Facebook are not always the best place to get information about businesses and their employees. There are other social networking sites that can be a bit more productive for you.

Username Search

Credentials are often used by attackers to gain access to resources they wouldn't otherwise have access to. Once you have identified people, getting their usernames may end up being useful. The tool Sherlock may be beneficial to identify people and their usernames. This is a program installed by default on ParrotOS. You provide a list of usernames you want to look for and it searches across hundreds of social networks for those usernames. Of course, finding a username is no guarantee that it is the person you are looking for. Knowing a username, though, does give you help with possible login attacks. Running Sherlock looks like this, having provided three different usernames and indicating a directory name to put the text files that will contain the output. This is a sample of the output from running this command.

Using Sherlock

```
$ sherlock --fo smithsearch jsmith smith johnsmith
[*] Checking username jsmith on:
[+] 7Cups: https://www.7cups.com/@jsmith
```



```
[+] 9GAG: https://www.9gag.com/u/jsmith
[+] About.me: https://about.me/jsmith
[+] Academia.edu: https://independent.academia.edu/jsmith
[+] Airbit: https://airbit.com/jsmith
[+] Airlines: https://www.airliners.net/user/jsmith/profile/photos
[+] AllMyLinks: https://allmylinks.com/jsmith
[+] Apple Developer: https://developer.apple.com/forums/profile/jsmith
[+] Apple Discussions: https://discussions.apple.com/profile/jsmith
[+] Archive of Our Own: https://archiveofourown.org/users/jsmith
[+] Archive.org: https://archive.org/details/@jsmith
[+] Arduino: https://create.arduino.cc/projecthub/jsmith
[+] Asciinema: https://asciinema.org/~jsmith
[+] AskFM: https://ask.fm/jsmith
[+] Audiojungle: https://audiojungle.net/user/jsmith
[+] BLIP.fm: https://blip.fm/jsmith
[+] Behance: https://www.behance.net/jsmith
[+] BiggerPockets: https://www.biggerpockets.com/users/jsmith
[+] Bikemap: https://www.bikemap.net/en/u/jsmith/routes/created/
```

LinkedIn

LinkedIn has been around for about two decades as of this writing. In spite of a number of competitors (such as Plaxo) going out of business or just no longer being in the space, LinkedIn is still around. It continues to expand its offerings beyond the very early days, when it was basically a contact manager. These days, LinkedIn is a business networking opportunity, highly useful for those in sales. It is also a great source for identifying jobs you may be interested in. It seems like human resources people, specifically recruiters, commonly use LinkedIn to find people to fill positions, whether it's an internal recruiter or someone who works for a recruiting company.

Because of the amount of business information LinkedIn collects, we can make use of it as a hunting platform. Especially with the paid memberships, LinkedIn does a lot of analytics about the businesses that make use of it, as well as the people who are on the site. If you are looking for information about a target, LinkedIn provides a lot of detail. Just as one example, [Figure 4.8](#) shows some statistics about applicants for a position that is open and advertised through the Jobs section of the website. This information requires a Premium subscription. We can see that the position attracts educated applicants. You can start to get a sense of the workforce by looking at these statistics across multiple positions.

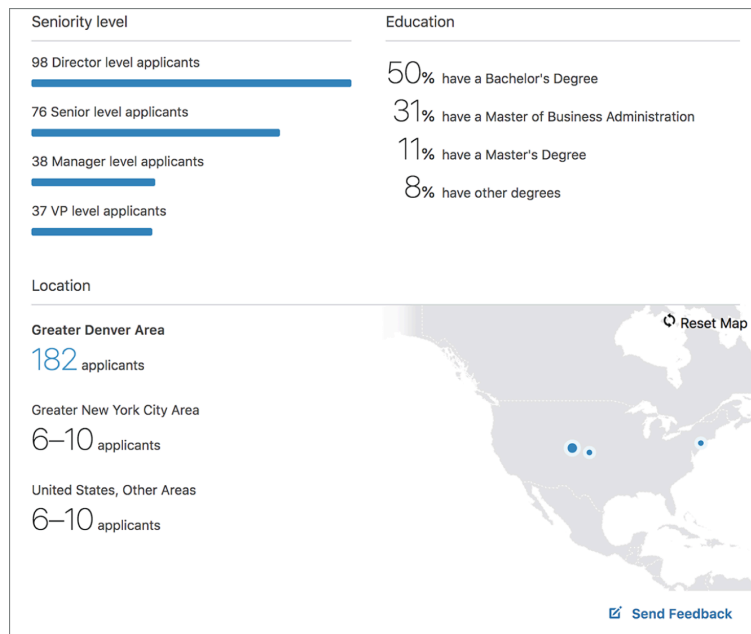


FIGURE 4.8 LinkedIn job statistics

Job listings are another place to look for details beyond the statistics about applicants and the workforce overall. What we can see from these listings is technology that may be in place within the organization. A listing for a network security engineer has requirements as shown in [Figure 4.9](#). While some of these requirements are generic, there are also some that are very specific about the technology in use in the network. For example, it appears that the company may be using Check Point on their site and Palo Alto Networks firewalls. Additionally, it has Cisco routers and switches in its network. This is a foothold. We can now start thinking about how to attack that sort of infrastructure. Cisco devices, for sure, have tools that can be run against them for various auditing and attack purposes.

Requirements:

- At least 5 years of experience with administration and implementation of IT security infrastructure(mainly CheckPoint, PaloAlto, ForeScout, ISA/TMG, F5)
- At least 5 years of experience with networking mainly Cisco switches, routers, Wifi as well as F5 load balancers
- Knowledge of AWS/ Azure /Google /365 cloud infrastructure is recommended
- Knowledge of networking protocols such as TCP/IP, BGP,OSPF,IPSEC, etc.
- A deep understanding of monitoring systems and procedures (SolarWinds Orian, PRTG, SNMP)
- Knowledge of authentication protocols such as OAuth, SAML, RADIUS, etc.
- Unified communication knowledge – an advantage

FIGURE 4.9 Job requirements for a network security engineer

We don't have to limit ourselves to the web interface, though, since it can be tedious to keep typing things and flicking through pages. Sometimes you want to be able to script a search without writing a program or manually using a web page. Formerly, there was a tool called InSpy that worked well for searching through LinkedIn. Unfortunately, the latest

version of InSpy available on Kali, 3.0.0, generates 404 errors trying to search for details. The instructions also require the use of an API key. With a little work, though, you can use another tool to do the LinkedIn searching for you.

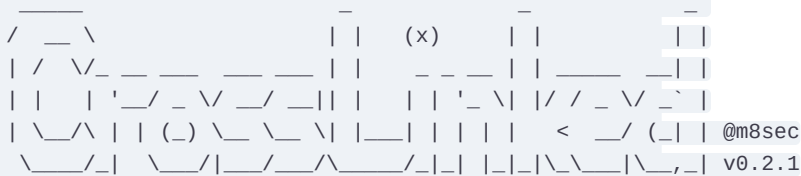
Beyond jobs, though, we can use LinkedIn to harvest information about people. There are a couple of reasons to look up people. One is just to get some names and titles that you may use later. Another is that even if job descriptions don't have information about technology, when people post their job responsibilities, they very often do. You can also get details about their certifications. Someone with a load of Cisco certifications, for example, is probably employed at a company that has a lot of Cisco equipment. Don't overlook nontechnical roles either. Anyone may provide a little insight into what you may find in the organization. You may get information about telephone systems and document management systems that the company uses, even if the employee isn't an administrator.

We will take a look at a tool called crosslinked.py here to do some searching for us.

CrossLinked Results from an Employee Search

```
$ git clone https://github.com/m8r0wn/crosslinked

Cloning into 'crosslinked'...
remote: Enumerating objects: 166, done.
remote: Counting objects: 100% (27/27), done.
remote: Compressing objects: 100% (25/25), done.
remote: Total 166 (delta 15), reused 4 (delta 2), pack-reused 139
Receiving objects: 100% (166/166), 66.85 KiB | 2.48 MiB/s, done.
Resolving deltas: 100% (72/72), done.
$ pip3 install -r requirements.txt
$ python3 crosslinked.py wiley -f wiley.com\flast --search google
```



```
[*] Searching google for valid employee names at "wiley"
[*] 99 https://www.google.com/search?q=site:linkedin.com/in+"Wiley"&num=100&start=0 (200)
[*] 198 https://www.google.com/search?q=site:linkedin.com/in+"Wiley"&num=100&start=99 (200)
[*] 297 https://www.google.com/search?q=site:linkedin.com/in+"Wiley"&num=100&start=198 (200)
[*] 298 https://www.google.com/search?q=site:linkedin.com/in+"Wiley"&num=100&start=297 (200)
[*] 298 https://www.google.com/search?q=site:linkedin.com/in+"Wiley"&num=100&start=298 (200)
[*] 298 https://www.google.com/search?q=site:linkedin.com/in+"Wiley"&num=100&start=298 (200)
[*] 298 https://www.google.com/search?q=site:linkedin.com/in+"Wiley"&num=100&start=298 (200)
[*] 298 https://www.google.com/search?q=site:linkedin.com/in+"Wiley"&num=100&start=298 (200)
[*] 298 names collected
```

The results of the search are placed in a comma-separated values file named names.csv. This is not a perfect utility, however, since it is not searching for employees at Wiley. Instead, you are getting everything that may have Wiley as part of the results, including people named Wiley. This includes people like a consultant named Calvin Wiley.

Twitter

Another common social networking site or service is Twitter. There is a lot posted to Twitter that can be of some use. Again, programmatic access to Twitter is useful. You can search using the regular interface, but it's sometimes helpful to be able to use other tools. To gain access to Twitter programmatically, you need to get an API key. This means you need to tell Twitter you are creating an application. You can easily tell Twitter you are creating an application without any special credentials through the Twitter developer's website. When you go through the process to create an application, what you are doing is creating identification information that your app needs to interact with the Twitter service. In [Figure 4.10](#), you can see keys and access tokens for an app.

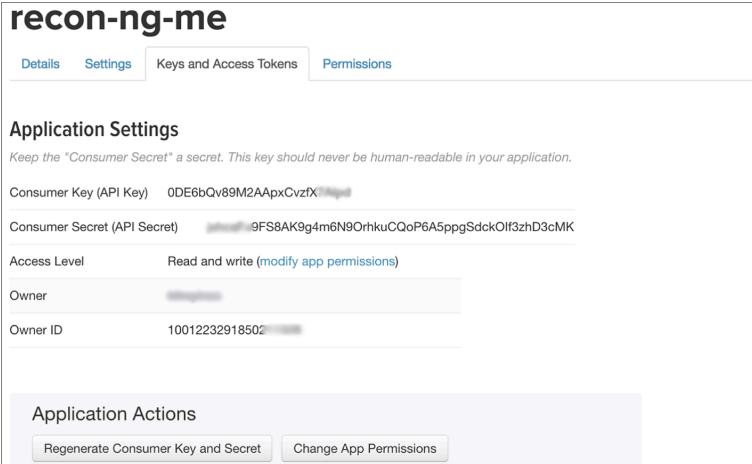


FIGURE 4.10 Twitter keys and access tokens

What you may notice in [Figure 4.10](#) is that the app is named recon-ng-me. The reason for this is that I created the app just to get the key and token so I could add it into recon-ng, a tool used for reconnaissance that includes many plugins. Some of these plugins require API keys or access tokens to be able to interact with the service being queried. That's the case with the Twitter plugin. In the following code, you can see the list of API keys that recon-ng uses and the API keys set for Twitter. Before you can use the key, you will need to get the module out of the marketplace in recon-ng using `marketplace install recon/profiles-profiles/twitter_mentions`.

recon-ng Keys

```
[recon-ng][default]> keys list
```

Name	Value
------	-------

bing_api	
builtwith_api	
censysio_id	
censysio_secret	
flickr_api	
fullcontact_api	
github_api	
google_api	
google_cse	
hashes_api	
ipinfodb_api	
jigsaw_api	
jigsaw_password	
jigsaw_username	
pwnedlist_api	
pwnedlist_iv	
pwnedlist_secret	
shodan_api	
twitter_api	0DE6bQv89M2AApXCvzfX7A1pd
twitter_secret	jxhcaFu9FS8AK9g4m6N90rhkuCQoP6A5ppgSdck0If3zhD3cMK

Now that we have the API key in place for Twitter, we can run the module. To run the module, we have to “load” it, meaning we load the module with the `modules load` command. Once it’s loaded, we have to set a source. In our case, the source is a text string, so it’s in quotes, telling `recon-ng` that we are using a text string for the source. The text string expected here is a user handle. The word *recon* was selected somewhat randomly and it got results. Once that’s done, all we need to do is run the module. You can see loading the module, setting the source, and running it in the following code. The results from the module are truncated because there were quite a few of them, and this is just to show you how to use the module.

Using Twitter Module in recon-ng

```
[recon-ng][default]> modules load recon/profiles/twitter_mentions
[recon-ng][default][twitter_mentions]> options list
```

Name	Current Value	Required	Description
-----	-----	-----	-----
LIMIT	True	yes	toggle rate limiting
SOURCE	default	yes	source of input (see 'show info' for details)

```
[recon-ng][default][twitter_mentions]> options set SOURCE 'recon'
SOURCE => 'recon'
[recon-ng][default][twitter_mentions]> run

'RECON'
[*] Category: social
[*] Notes: Pentester Academy
[*] Resource: Twitter
[*] Url: https://twitter.com/SecurityTube
[*] Username: SecurityTube
[*] -----
```

```

[*] Category: social
[*] Notes: Pentester Academy
[*] Resource: Twitter
[*] Url: https://twitter.com/SecurityTube
[*] Username: SecurityTube
[*] -----
[*] Category: social
[*] Notes: Tony Lazzari
[*] Resource: Twitter
[*] Url: https://twitter.com/TonyLazzariXXX
[*] Username: TonyLazzariXXX
[*] -----
[*] Category: social
[*] Notes: Michael Lee
[*] Resource: Twitter
[*] Url: https://twitter.com/jocko2001
[*] Username: jocko2001
[*] -----
[*] Category: social
[*] Notes: Josh Morgerman
[*] Resource: Twitter
[*] Url: https://twitter.com/iCyclone
[*] Username: iCyclone
[*] -----
[*] Category: social
[*] Notes: JBC Trader
[*] Resource: Twitter
[*] Url: https://twitter.com/JbcTrader
[*] Username: JbcTrader
[*] -----
[*] Category: social
[*] Notes: wx_fit2024
[*] Resource: Twitter
[*] Url: https://twitter.com/wx_fit2024
[*] Username: wx_fit2024
[*] -----

```

Because we are running the twitter-mentions module, we are using the text string to search for mentions in Twitter. What we get back are profiles from users that were mentioned by a given handle. You could do the reverse of these results with the twitter_mentioned module, which returns profiles that mentioned the specified handle. Finally, we can look for tweets that happened in a given geographic area using the locations-pushpin/twitter module. We can specify a radius in kilometers within which we want to search using this module.

There is another tool that's useful for reconnaissance overall, but since it has Twitter abilities, we'll take a look at it here. Maltego uses a visual approach by creating graphs from the data that has been collected. It can be useful to have entity relationships identified, like parent-child relationships between pieces of data. Maltego uses transforms to pivot from one piece of information to another. A collection of transforms is called a machine, and it's a good place to start. [Figure 4.11](#) shows part of the output from Twitter Digger X, which analyzes tweets from the username provided. As you can see, you get a graph that is structured like a tree. This is

because every piece of data collected can potentially yield another piece, which would be a child.

Maltego can be a good tool to collect reconnaissance data, especially if you want a visual representation of it. While there are several other tools that can collect the same data Maltego does, Maltego does have the advantage of giving you a quick way to collect additional data by just selecting a node on the graph and running a transform on it to pivot to another data collection tool. You can start with a hostname, for instance, and collect an IP address from it by just running a transform.

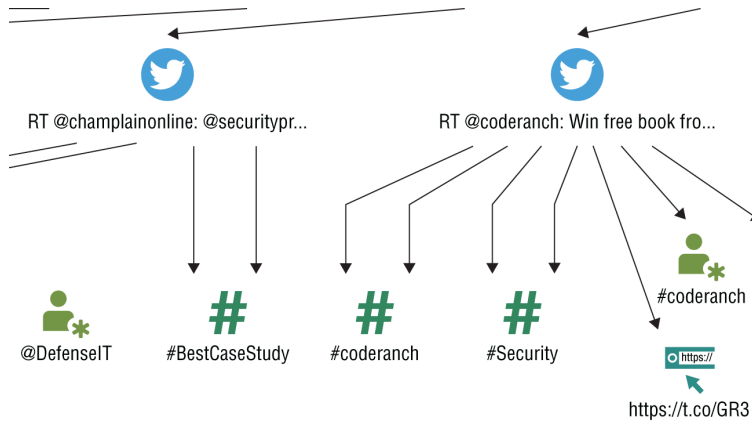


FIGURE 4.11 Maltego graph from Twitter

There are additional Twitter machines and transforms aside from Twitter Digger X. You can also monitor Twitter for the use of hashtags, for example. This will provide a lot of capability, in addition to all of the other capabilities, to search Twitter from inside Maltego.

HANDS-ON ACTIVITY

Obtain a copy of Maltego Community Edition. It will require you to register to use it. It can be installed from the repositories on Kali Linux and ParrotOS. Use Maltego to locate as much information about yourself as you can using the machines and transforms available.

Job Sites

Earlier we looked at LinkedIn as a source of information. One area of information we were able to gather from LinkedIn was job descriptions, leading to some insights about what technology is being used at some organizations. For example, [Figure 4.12](#) shows some qualifications for an open position. This is for a senior DevOps engineer, and the listing was on [indeed.com](#). While the technologies are listed as examples, you certainly have some starting points. You know the company is using relational databases. This isn't surprising, perhaps, since so many companies are using them. It does tell you, though, that they aren't using NoSQL, which includes things like MongoDB and Redis. You also know that they are using Amazon Web Services. Since they are looking for someone certified there, this is a certainty.

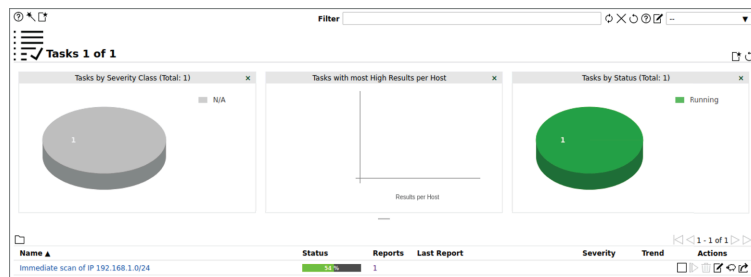


FIGURE 4.12 Job listing with technologies

If you wanted to try to do something through the web application, you know they are using RESTful interfaces for the application. It's not much, but it's a starting point. As you look over job listings, you start to be able to read them with an eye toward picking out potential targets. After you've been reading them for a while, you will start to pick out some of the language of these listings. As an example, the listing uses the word *like* in several of the lines. While you can't get a complete line on what is used, you can certainly rule some things out.

There are a lot of places to go looking for job listings. While in the old days, we used newspapers, and you'd have to get a newspaper in the region you wanted to look for a job in (or scare up information about a company you were trying to research), now job postings are everywhere online. Some of the big websites you might use are Monster, Indeed, Glassdoor, CareerBuilder, and Dice. You should also keep the company itself in mind. While many companies use the job posting sites, there may be some companies that post jobs on their own site, and they may not be available elsewhere. You may also check specialized sites like USAJobs and ClearanceJobs.

Any of these job postings may provide you with some insight into not only technology but also organizational structure. As I mentioned earlier, don't focus only on technology listings. You can gather additional information about the company using other job listings that aren't about technology.

Domain Name System

While you can gather a lot of information at a distance, at some point, you need to dive in. This still doesn't mean you are going fully active, but you're going to start gathering details about the scope of what we are dealing with. When you interact with systems on your target, and every other system as well, you need to communicate with an IP address. However, humans aren't good at remembering strings of numbers. Instead, we use fully qualified domain names (FQDNs), but that means we need something that will translate these FQDNs into IP addresses for us. This is where the DNS comes in.

DNS is a tiered system, and it's tiered in a couple of ways. First is the FQDN we use. I can use an example here to help to demonstrate.

www.labs.domain.com is an FQDN because it refers to a specific host or system. It's best to read the FQDN from right to left, because that's how DNS will read it when it comes time to resolving the FQDN to an IP address. In the beginning were the top-level domains (TLDs), and they were

.com, .org, and .edu, as well as all the ones for the different countries (.uk, .au, .ca, .sk, .us, and so on). Later, many more were added, but they are all still TLDs. They are considered top-level domains because you might graph DNS like a tree. All the TLDs would be at the top, and then everything grew out from those TLDs.

Second-level domains are where we start adding in organizations. The TLDs belong to the Internet at large, so to speak. They have organizations that manage them, but they don't "belong" to any one organization, at least not in the way the second-level domains can be said to. In our example, the second-level domain would be *domain*. When people refer to domains, they generally refer to the second-level domain along with the TLD, or domain.com in our example.

Under second-level domains are subdomains. Every domain can have as many levels of subdomains as they are willing to manage. We have a subdomain in the example. The subdomain is *labs*, and it belongs to the domain domain.com. When we add *www*, which is the hostname, to the subdomain, the second-level domain, and the TLD, we end up with something called a fully qualified domain name (FQDN). It's fully qualified because it's clear what domain the hostname belongs to (the hostname *www*, for instance, exists in countless domains) and it's also clear what hostname in the domain we are talking about.

You may recognize the three letters *www* as standing for World Wide Web, which it also stands for here. When the letters are meant to refer to the World Wide Web, they are capitalized—WWW. When you see *www*, it will refer to a hostname rather than the overall World Wide Web.

Now that you have a basic understanding of the naming structure used within DNS and a basic understanding of what DNS is used for, we can start looking at how you might use DNS to gather information about your targets. First, we'll start with name lookups. This includes how a name lookup actually works, and then we'll look at some tools that can be used to perform the name lookups. After that, we'll look at doing zone transfers, which are essentially bulk name lookups.

Name Lookups

When you visit a website, you enter something called a Uniform Resource Locator (URL). The URL consists, commonly, of two parts. The first is the Uniform Resource Identifier (URI). This is the protocol used (e.g., http:// or ftp://). Following the URI is the FQDN. Your browser will issue a request to the operating system to open a connection to the FQDN at the default port indicated by the URI. Before the connection can be opened, however, the system needs to have an IP address to put into the layer 3 headers. So, it issues a name resolution request. Each computer will have at least one name resolver configured. The name resolver is the system your computer goes to in order to accomplish the name resolution.

This description assumes that your computer has never visited the site before. Your system will commonly cache the resolved address so it doesn't have to generate network traffic to ask again. Similarly, the resolver your system asks will also generally cache results so it doesn't have to keep asking its authoritative server. We similarly assume that no other system using the same resolver has requested the information, resulting in a fresh request.

The name resolver for TCP/IP networks is a DNS server, though other network protocols will use other name services. It takes in DNS requests and resolves them, based on what is being asked. Typically, the name resolver you will have configured will be what is called a caching name server. This means it gets requests from endpoints, resolves them, and caches the results for efficiency. This is distinct from what is known as an authoritative server, which holds the records for a given domain. We'll get to authoritative servers shortly. So, the first DNS request is the one from your system to the caching server, wherever it happens to be located. [Figure 4.13](#) shows a basic flow of how a complete DNS name resolution would work, so you can follow along there.

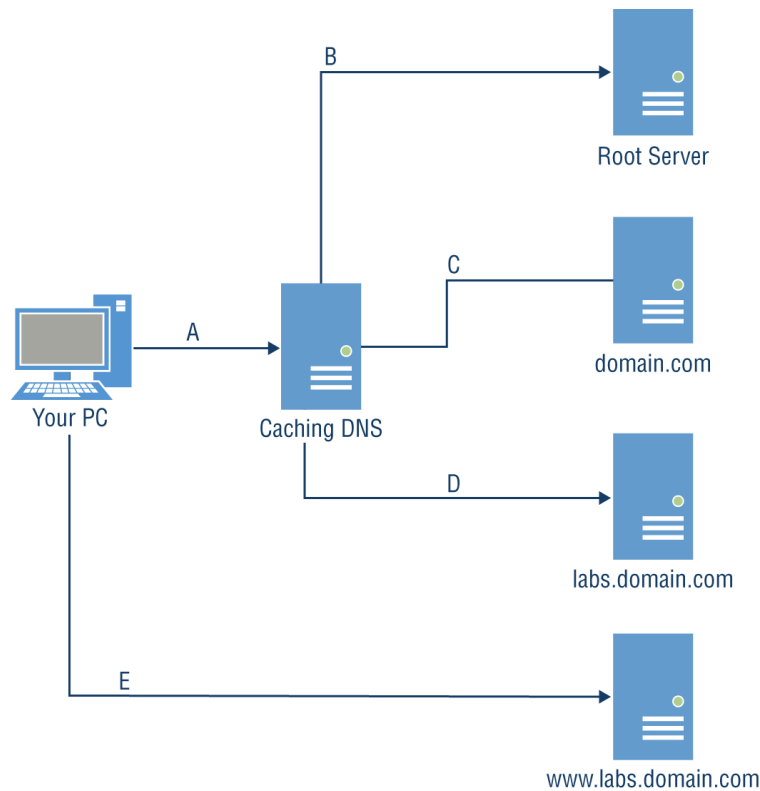


FIGURE 4.13 DNS name resolution

We start with the request labeled A. This goes to the name resolver, labeled Caching DNS. The caching DNS server checks its cache and sees that it has no IP address stored, so it begins something called a *recursive name query* or *recursive name resolution*. It's called *recursive* because it will end up with multiple requests that keep getting narrower until we end up with what we want. The caching server will need to start with the TLD. It will have a hints file, indicating the IP addresses for the root name

servers. For our example, the caching server will need to identify the server to use for the `.com` TLD. Once it has identified the server it needs to send a request to, request B goes out, asking the root server for the IP address of the name server for the `domain.com` domain.

The root server has the name server details for all the domains that fall under the TLD it is responsible for. The root server will reply to our caching server with the IP address for the name server for `domain.com`. When we did the `whois` lookups earlier, at the end of a `whois` lookup on a domain will be the name servers for that domain, since the name servers are stored with the domain. This, though, is why what we are doing is called a *recursive query*. We can't just ask the root server for the IP address of the hostname, so we have to ask it for a pointer to who to ask next.

Request C is the DNS request asking the authoritative name server for `domain.com` about `labs.domain.com`. Since `labs.domain.com` is separate from `domain.com`, what our caching server gets back is another name server. This means one more request. We are now at the point where the FQDN is being asked for. Request D goes out asking for the IP address of `www.labs.domain.com`. The authoritative server, which is the one we are asking because it has the authoritative information about that domain, responds with the IP address. It may actually respond with multiple IP addresses, but for our purposes, we're going to just say it comes back with a single IP. Once the caching server has the IP, it sends the response back to our system, which can then issue request E, which isn't a DNS request but a connection request to the web server.

While DNS stores mappings between FQDNs and IP addresses, those are not the only data mappings that are stored. Some of the different record types you can and may want to look up include:

- A: An A record is an address record and it converts an FQDN to an IP address.
- AAAA: An AAAA record converts an FQDN to an IPv6 address.
- MX: Every domain has a mail exchanger record, used to indicate the host that email should be sent to for that domain.
- NS: The name server records are the FQDNs and IP addresses of the authoritative name servers for that domain.
- SOA: The start of authority record holds information about the zone, including the serial number, indicating when zone information has changed last.
- CNAME: A canonical name is an alias for an FQDN. This maps one hostname to another hostname or FQDN. The CNAME may refer to specifically a hostname since the domain name may already be assumed if it's in the same domain.
- PTR: A pointer from an IP address to an FQDN. Unlike an A record, this is not necessary, but it is considered useful. An FQDN always has to map to an IP address but an IP address does not have to map to a hostname. Often multiple FQDNs may map to a single IP address.

There are other records, some of which relate to email security to indicate signing keys to verify messages from a trusted email server. Another

record is the TXT record, used to store text entries that don't have specific purposes but can be used for a variety of purposes. Now that you have a handle on the process we are going through to get IP addresses back from DNS servers and some of the information we can collect, we can start looking at tools we can use to get those addresses.

Using *host*

Perhaps the easiest tool to use is `host`. This is a program that you will find on most Unix-like systems, including Linux systems. It has no Windows analog, unfortunately. If you don't have it installed by default, you can probably get it installed. Using it is very straightforward. You just pass the hostname you want the IP address for to `host` and you will get a response. You can see an example of that in the following code.

DNS Lookup Using `host`

```
$ host www.sybex.com
www.sybex.com has address 208.215.179.132
$ host www.sybex.com 4.2.2.1
Using domain server:
Name: 4.2.2.1
Address: 4.2.2.1 # 53
Aliases:

www.sybex.com has address 208.215.179.132
$ host 208.215.179.132
132.179.215.208.in-addr.arpa domain name pointer motorfluctuations.net.
132.179.215.208.in-addr.arpa domain name pointer managementencyclopedia.org.
132.179.215.208.in-addr.arpa domain name pointer smdashboard.wiley.com.
132.179.215.208.in-addr.arpa domain name pointer elansguides.com.
132.179.215.208.in-addr.arpa domain name pointer currentprotocols.net.
132.179.215.208.in-addr.arpa domain name pointer geographyencyclopedia.com.
132.179.215.208.in-addr.arpa domain name pointer separationsnow.info.
132.179.215.208.in-addr.arpa domain name pointer jcsm-journal.com.
132.179.215.208.in-addr.arpa domain name pointer literature-compass.com.
```

In addition to just a straightforward lookup of an IP address, we can use a different server than the one that is defined as our resolver. You can see in the second request, I added an IP address to the command line. This IP address is a caching server that is available for anyone to use. It was created by BBN Planet in the 1990s and, alongside similar services by Google and Cloudflare, can be used by anyone on the Internet. Since it is also a caching server that is open for anyone to use, we can issue requests to it and it will go through the same process described earlier, just as if it were our own caching server.

You can also see from the example, where it says `host 208.215.179.132`, that you can look up an FQDN from an IP address. DNS servers may store mappings from FQDNs or hostnames to IP addresses, allowing something called a *reverse lookup*. This means that we have an IP address, and we want the hostname that's associated with it. As you can see, often an IP address will have several hostnames associ-

ated with it. This may be the case where a web server is hosting virtual servers—meaning the web server can determine what content to serve up based on the hostname in the request. The request for this IP address resulted in 197 responses, but they have been truncated for space.

Using *nslookup*

Another tool that can be used is `nslookup`. This can be used just like the program `host`, meaning you could just run `nslookup www.sybex.com` and get a response. An advantage to `nslookup`, however, is that you can issue many requests without having to keep running `nslookup`. When you run `nslookup` without any parameters, you will be placed into an `nslookup` shell, where you are interacting with the program, issuing requests. In the following code, you can see an exchange in `nslookup`. We are ultimately looking for the same information as we got earlier using `host`, but we are going about it in a different manner.

Using `nslookup` for Name Resolution

```
$ nslookup
> set type=ns
> sybex.com
Server:      192.168.86.1
Address:     192.168.86.1#53
```

Non-authoritative answer:

```
sybex.com    nameserver = jws-edcp.wiley.com.
sybex.com    nameserver = ns.wiley.co.uk.
sybex.com    nameserver = ns2.wiley.co.uk.
sybex.com    nameserver = sg-ns01.wiley.com.
sybex.com    nameserver = bri-ns01.wiley.com.
sybex.com    nameserver = ns.wileypub.com.
```

Authoritative answers can be found from:

```
> set type=A
> server ns.wileypub.com.
Default server: ns.wileypub.com.
Address: 12.165.240.53#53
> www.sybex.com
Server:      ns.wileypub.com.
Address:     12.165.240.53#53
```

```
Name:      www.sybex.com
Address:    208.215.179.132
```

Instead of just looking up the IP address from the FQDN, I used resource records to start. DNS supports multiple resource records, though the most common is the address (A) record. When you see `set type=ns`, I'm telling `nslookup` to issue subsequent requests asking for name server

(NS) records. This will tell us the authoritative name servers for the given domain. Once I had the list of NSs, I was able to set the server I was asking to one of the NSs. What this means is that instead of going to my caching server, `nslookup` is going to issue a DNS request directly to the authoritative server, which wouldn't have to do any recursive search since it has the information being requested.

Using *dig*

The program `dig` is another utility that can be used for name resolutions. It also supports the same things we have been doing, meaning we can indicate a different name server and also request different resource records. An example using `dig` can be seen in the following code. The command line has all the information for the request, including the resource record type, the request, and also the server `dig` should issue the request to.

Using `dig` for DNS Lookups

```
$ dig mx wiley.com @car-ibextdns-01.wiley.com

; <<>> DiG 9.10.6 <<>> mx wiley.com @car-ibextdns-01.wiley.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 47684
;; flags: qr aa rd; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1220
;; QUESTION SECTION:
;wiley.com.                IN      MX

;; ANSWER SECTION:
wiley.com.                900     IN      MX      10 mxa-0053b401.gslb.pphosted.com.
wiley.com.                900     IN      MX      10 mxb-0053b401.gslb.pphosted.com.

;; Query time: 62 msec
;; SERVER: 63.97.119.2#53(63.97.119.2)
;; WHEN: Tue Feb 28 17:13:30 EST 2023
;; MSG SIZE rcvd: 110
```

The response is quite a bit more detailed than we've seen so far. First, we can see the parameters `dig` used while it was running. These parameters can be changed as needed. After the parameters, you can see the question section. This makes it very clear what the request was. You can compare that to what you asked for, in case there is any confusion based on what you specified on the command line. Finally, we get the result.

In this example, the type is MX, which is the mail exchanger record. The DNS server will respond with a list of all the mail servers that have been configured in DNS for that domain. When you want to send email to someone, your mail server will issue a DNS request asking which mail

server it should be sending mail to for the domain requested. The mail servers are listed with a number. The lowest number is the preferred mail server. If, for whatever reason, you can't reach that mail server, you move on to the next one and so on until you run out of mail servers and have to fail the message.

Using `dig`, we can do exactly what we did earlier with `host` and `nslookup`. On the command line, you indicate the resource record you want. In our command line (`dig mx wiley.com @car-ibextdns-01.wiley.com`), `mx` is the resource record being requested, but it could just as easily be `A` or `NS`. It could also be `PTR`, if we wanted to get back an IP address from an FQDN. After the record type is the request. Since we are looking for a mail exchanger record, this would be a domain name, though you could issue an FQDN here, and you would get the mail exchanger records for the last domain that's part of the FQDN. Finally, we indicate the server to ask using the `@` sign.

Zone Transfers

Issuing single requests is fine, but it assumes you know some information. In most cases, applications are asking for the information about IP addresses from FQDNs so the application can function correctly. In our case, as ethical hackers, we are sometimes looking for all the hostnames that belong to a domain. This can be done using something called a *zone transfer*. A zone transfer is legitimately used between multiple authoritative NSs in a domain to keep the servers in sync. You might have a primary authoritative server for a domain and then multiple secondary servers. The secondary servers would issue a zone transfer request to the primary and update their records accordingly.

We can use that capability, theoretically, to request all the records in a domain. Because of this capability, though, two things have happened. First, most domains you will run across won't allow zone transfers from anyone other than the secondary NSs that have been configured. Second, many companies use something called split DNS. Split DNS is where the outside world is given an authoritative server address to use for externally resolvable hosts, like the web server and the mail server. Any system inside the enterprise network would use the company resolver, which would be configured as authoritative for the corporate domain. This means it can have many other systems that are not known or available to the outside world but that internal systems can resolve and connect to.

To issue a zone transfer request, you can use the utilities we've already been using, though there are others. If you wanted to attempt a zone transfer using `dig`, for instance, the request type would be `axfr`. You can see an example of using `dig` to request a zone transfer in the following code.

Zone Transfer Using `dig`

```
$ dig axfr domain.com @192.168.86.51
```

```

; <<>> DiG 9.10.6 <<>> axfr domain.com @192.168.86.51
;; global options: +cmd
domain.com.      86000      IN      SOA      ns.domain.com. root.domain.com. 1 604800 86400 2
domain.com.      86000      IN      NS       ns.domain.com.
blagh.domain.com. 86000      IN      A        172.16.56.10
ftp.domain.com.   86000      IN      A        10.5.6.10
lab.domain.com.   86000      IN      A        172.16.56.7
ns.domain.com.    86000      IN      A        192.168.86.51
wubble.domain.com. 86000      IN      A        172.30.42.19
www.domain.com.   86000      IN      A        192.168.75.24
domain.com.      86000      IN      SOA      ns.domain.com. root.domain.com. 1 604800 86400 2
;; Query time: 20 msec
;; SERVER: 192.168.86.51#53(192.168.86.51)
;; WHEN: Thu Jul 05 10:15:27 MDT 2018
;; XFR size: 9 records (messages 1, bytes 243)

```

Brute Force

As zone transfers are generally disallowed, you may have to rely on less elegant solutions to gather information about your target. Fortunately, there are some tools that may be of help here. One is `dnsrecon`, which can be used to extract some of the common resource records in DNS. Additionally, it can be used to identify hostnames as a result of repeated requests based on a word list provided to the program. In the following code, `dnsrecon` is used to do a brute-force scan. The word list provided has a number of possible hostnames. These hostnames are prepended to the provided domain name, and then the resulting FQDN is checked. You can see a portion of the results from the scan.

Using `dnsrecon` to Acquire Hostnames

```

$ dnsrecon -d wiley.com -D /usr/share/wordlists/dnsmap.txt -t brt
[*] Performing host and subdomain brute force against wiley.com
[*] A act.wiley.com 209.172.193.49
[*] A adc.wiley.com 192.168.5.1
[*] A ags.wiley.com 209.172.193.49
[*] A api.wiley.com 209.172.192.180
[*] A bcs.wiley.com 209.172.193.216
[*] CNAME bpa.wiley.com internal-bpa-private-app-prod-elb-405571586
.us-east-1.elb.amazonaws.com
[*] A internal-bpa-private-app-prod-elb-405571586.us-east-1.elb.amazonaws
.com 10.223.11.111
[*] A internal-bpa-private-app-prod-elb-405571586.us-east-1.elb.amazonaws
.com 10.223.139.133
[*] A bpm.wiley.com 10.6.1.241
[*] A bps.wiley.com 10.6.2.91
[*] A cct.wiley.com 209.172.194.98
[*] CNAME cec.wiley.com d1hsh8hpdo3jj3.cloudfront.net

```

In some cases, looking up an IP address results in an alias. In the output, these show up as canonical name (CNAME) responses. The CNAME refers to another hostname or FQDN, and that hostname or FQDN is then resolved until there is an IP address. There can be multiple layers of

CNAMEs that need to be resolved. Some of these IP addresses are private, but some others are public IP addresses. These IP addresses could be chased down.

HANDS-ON ACTIVITY

You will get a good idea how to start to size a footprint with this activity. Select a domain, ideally one you have some association with. Identify, using some of the techniques described in the preceding sections, some of the hosts associated with the domain. Once you have the IP addresses, identify the address blocks and who owns them. Keep track of all the IP addresses and address blocks owned by the company or organization associated with the domain.

Passive DNS

In practice, there are two different phases of reconnaissance. While there is a lot of focus on gathering information to launch attacks, there is a lot of reconnaissance that happens after exploitation as well. You can perform reconnaissance from the outside as well as from the inside. Once you are on the inside, some of this gets a little easier, or at least we open some other doors for reconnaissance. A technique of using cached DNS entries on a local system is called *passive* DNS reconnaissance.

Each time you perform a DNS lookup on some systems, the result will be cached locally. This caching of the address saves having to send a network request the next time you want to visit the same host. The length of time the entry will be cached is set by the time to live field in the DNS entry. This begins with the start of authority (SOA) record. This indicates when the domain record itself expires. Effectively, this tells anyone looking for information about the domain when they need to check again to see who the authoritative domain name servers are. There are NS records associated with every domain indicating what servers to ask for answers about that domain. These authoritative servers should always be asked unless a record is cached locally, whether directly on the client requesting the information or the local caching server the client is asking.

In addition to the SOA record providing the timeout length for the domain itself, meaning the length of time you can rely on the name servers being valid before needing to check again, each individual record stored in DNS can have a time to live (TTL) value. This indicates how long any system can cache the result before checking again with the authoritative DNS server to ensure the value hasn't changed. According to the specification for DNS, you don't wait until the very end of the lifetime of an entry but instead use some value that is less than the full TTL. The TTL does provide guidance, though, on how long to hold on to a value in your local cache.

Windows systems will cache values, and you can dump the cache on them, as you can see in the partial dump that follows here. To dump the cache on a Windows system, you would use command-line access, either the old command line or, using a PowerShell-based command line, you

would just run `ipconfig /displaydns`. On Linux systems, you can get the same information only if your system is running a caching server. This may be a program like `dnsmasq`, which does DNS forwarding, or it could be the `nscd` service, which is the name server caching daemon. You'll see for each of the records here, there is a time to live (TTL) value.

Using ipconfig

```
PS C:\Users\Ric Messier> ipconfig /displaydns

Windows IP Configuration

vortex.data.microsoft.com
-----
Record Name . . . . . : vortex.data.microsoft.com
Record Type . . . . . : 5
Time To Live . . . . . : 24
Data Length . . . . . : 8
Section . . . . . : Answer
CNAME Record . . . . . : asimov.vortex.data.trafficmanager.net

Record Name . . . . . : asimov.vortex.data.trafficmanager.net
Record Type . . . . . : 1
Time To Live . . . . . : 24
Data Length . . . . . : 4
Section . . . . . : Answer
A (Host) Record . . . : 64.4.54.254

array511.prod.do.dsp.mp.microsoft.com
-----
Record Name . . . . . : array511.prod.do.dsp.mp.microsoft.com
Record Type . . . . . : 1
Time To Live . . . . . : 1489
Data Length . . . . . : 4
Section . . . . . : Answer
A (Host) Record . . . : 52.184.213.21

1.0.0.127.in-addr.arpa
-----
Record Name . . . . . : 1.0.0.127.in-addr.arpa.
Record Type . . . . . : 12
Time To Live . . . . . : 541542
Data Length . . . . . : 8
Section . . . . . : Answer
PTR Record . . . . . : kubernetes.docker.internal

download.visualstudio.microsoft.com
-----
Record Name . . . . . : download.visualstudio.microsoft.com
Record Type . . . . . : 5
Time To Live . . . . . : 33
Data Length . . . . . : 8
Section . . . . . : Answer
CNAME Record . . . . . : 2-01-5830-0005.cdx.cedexis.net
```

```

Record Name . . . . . : 2-01-5830-0005.cdx.cedexis.net
Record Type . . . . . : 5
Time To Live . . . . . : 33
Data Length . . . . . : 8
Section . . . . . : Answer
CNAME Record . . . . . : 4316b.wpc.azureedge.net

Record Name . . . . . : 4316b.wpc.azureedge.net
Record Type . . . . . : 5
Time To Live . . . . . : 33
Data Length . . . . . : 8
Section . . . . . : Answer
CNAME Record . . . . . : cs10.wpc.v0cdn.net

Record Name . . . . . : cs10.wpc.v0cdn.net
Record Type . . . . . : 28
Time To Live . . . . . : 33
Data Length . . . . . : 16
Section . . . . . : Answer
AAAA Record . . . . . : 2606:2800:11f:7de:d31:7db:168f:1225

array513.prod.do.dsp.mp.microsoft.com
-----
Record Name . . . . . : array513.prod.do.dsp.mp.microsoft.com
Record Type . . . . . : 1
Time To Live . . . . . : 1202
Data Length . . . . . : 4
Section . . . . . : Answer
A (Host) Record . . . . : 52.184.214.53

```

If you are doing external reconnaissance, this technique is unlikely to be of much use to you. Once you gain access to the inside of the network, though, you want to know all of the systems and IP addresses. From the outside, you can query open sources for details about address blocks that may be owned by the organization. On the inside of the network, they are probably using private addresses. There is no record anywhere of the blocks being used, unless you happen to get access to a network management system that records all the address blocks. Instead, what you can do is dump the DNS cache on a system you have access to. What you will get is not only hostnames but also the IP addresses that resolve to those hostnames. If you see a lot of entries for the domain owned by the company in the cache dump, you may well be seeing internal DNS records. Another way you may know you have internal addresses is if you see something that ends in `.local`. This is a top-level domain that can't be used across the Internet, so it is sometimes used as a top-level domain (the last part of the fully qualified domain name that includes the hostname and the domain name) for internal DNS implementations.

It is common for companies to use an implementation called *split DNS*, where there is one server for the outside world, with a limited number of records. Typically, you'd have FQDNs for any system that exposes essential services to the outside world. On top of the external DNS, there is probably an internal DNS. This is where all the systems inside the net-

work get registered so you can use FQDNs rather than IP addresses. Your own system on an enterprise network may register with the DNS server so someone trying to get to your system would just refer to the FQDN of your system and be able to resolve that FQDN to an IP address.

Passive Reconnaissance

There is a lot of information that can be collected in a passive manner. For example, watching the network headers as they go by, from the layer 3 headers to the application headers, can turn up some interesting information. While it can be time-consuming to capture packets and try to read through them manually, there is a program that will do a lot of that work for us. The program is `p0f`, and it will sit and watch network traffic as it passes by the interface, making observations as the traffic passes. Unfortunately, `p0f` isn't as useful as it once was. The reason for that has nothing to do with `p0f` but more to do with the fact that web servers are generally encrypting traffic by default, which means `p0f` can't watch the HTTP headers, identifying the server and other useful information. Here you can see some of the output from `p0f`.

Output from `p0f`

```
.-[ 192.168.86.45/46112 -> 8.43.72.22/443 (syn) ]-
|
| client   = 192.168.86.45/46112
| os       = Linux 3.11 and newer
| dist     = 0
| params   = none
| raw_sig  = 4:64+0:0:1460:mss*20,7:mss,sok,ts,nop,ws:df,id+:0
|
|-----

.-[ 192.168.86.45/46112 -> 8.43.72.22/443 (mtu) ]-
|
| client   = 192.168.86.45/46112
| link     = Ethernet or modem
| raw_mtu  = 1500
|
|-----

.-[ 192.168.86.45/46112 -> 8.43.72.22/443 (uptime) ]-
|
| client   = 192.168.86.45/46112
| uptime   = 48 days 7 hrs 54 min (modulo 49 days)
| raw_freq = 1000.00 Hz
|
|-----

.-[ 192.168.86.45/33498 -> 52.94.210.45/443 (syn) ]-
|
| client   = 192.168.86.45/33498
| os       = Linux 3.11 and newer
| dist     = 0
| params   = none
| raw_sig  = 4:64+0:0:1460:mss*20,7:mss,sok,ts,nop,ws:df,id+:0
|
```

```
`-----`  
  
.- [ 192.168.86.45/33498 -> 52.94.210.45/443 (host change) ] -  
|  
| client    = 192.168.86.45/33498  
| reason    = tstamp port  
| raw_hits  = 0,1,1,1  
|  
`-----`
```

Very little of what you see here is anything you wouldn't be able to determine yourself if you knew how to read packet headers. The packet capture and analysis program Wireshark could provide much of this information. Some of the interesting bits, though, include identifying system uptime. This is the uptime on systems on my local network, so it's less interesting, perhaps, than it would be if we could so easily identify uptime on remote systems. You can also see that `p0f` is able to identify the operating system type on some systems. It happens to be the system that `p0f` is running on, but it makes the determination based on the network headers since operating systems have different “signatures” that are based on how the IP identification number is generated, how the TCP sequence number is generated, how ephemeral port numbers are selected, and other pieces of information `p0f` can collect.

One tool you can use to quickly look up information from your web browser is Recon. This is a plugin for web browsers like Firefox and Chrome. When you activate it, a window that looks like what you see in [Figure 4.14](#) opens. You can see the different flyout menus that allow you to do additional searching quickly. While this isn't strictly passive reconnaissance, it does give you quick access to tools like `whois` lookups, Google dorks, and other important searches. You can do this all without directly opening another tab or window.

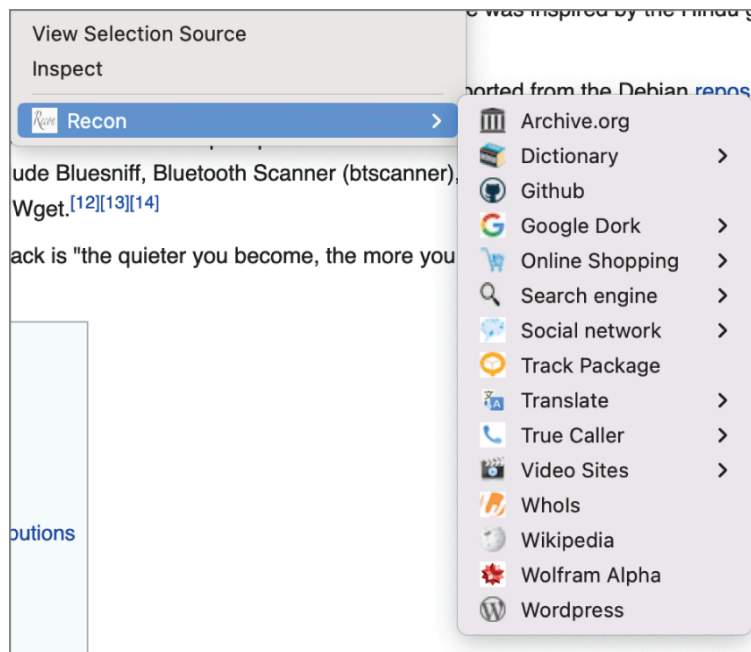


FIGURE 4.14 Recon with Recon

You may not be using Firefox, though what you'll probably find is that the browser that has the majority of plugins that are useful for security testing is Firefox. I used to joke that Firefox was the browser that was insecure enough to allow plugins access to do all sorts of bad things. This isn't true, of course. Plugins have been around for Firefox much longer than for other browsers, so the development community has been around for a while. Other browsers, like Chrome, can be much more restrictive in what they will allow developers to do, though, which also makes Firefox more attractive. This continues to change, so it's always worth checking to see whether the browser you like to use has plugins or extensions available to do security testing with.

One plugin or extension available in Chrome is Recon. This provides a context menu when you right-click a link in a page. The Recon menu gives you quick access to look up information about the link or word you have selected. You can do Google or Bing searches, for example, and Recon will open a new tab or window with the results of a search on what you have selected. You can also get translations of words, do package tracking, search video sites, and perform a number of other quick searches where your selection is passed into the site you have selected from the menu.

These sorts of tools can be invaluable to quickly search for answers, though they aren't passive reconnaissance in the same sense that watching network traffic is. However, this is not at all to say that the information you can get from these tools isn't valuable. Any tool that can save you time and maybe even expose you to a new technique you could add to your arsenal is very valuable. Even with all of this, there is still information we can look at that we haven't seen as yet.

Website Intelligence

It would be difficult to find a company that had no web presence at all. It's possible, of course, though it's unlikely. Even small companies probably have a page on Facebook to show the hours they are open. Companies that may be most prone to need the services of an ethical hacker to perform testing will likely have a website. It may even have programmatic elements. Any site that has programmatic elements has the potential to be compromised. Web applications are a common point of attack for adversaries. This is all to say that gathering intelligence about a website can end up bearing fruit.

Starting from the bottom of the stack, we can look at what the web server is as well as the operating system. One way to get some of this information is just to connect to the web server and issue a request to it. In the following code, you can see the HTTP headers returned from a request to a website. While we don't get the actual web server name, we do get some interesting information.

Gathering Website Intelligence

```
HTTP/1.1 403 Forbidden
Date: Sun, 13 Nov 2022 21:13:14 GMT
Content-Type: text/plain; charset=UTF-8
Content-Length: 16
Connection: keep-alive
X-Frame-Options: SAMEORIGIN
Referrer-Policy: same-origin
Cache-Control: private, max-age=0, no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Expires: Thu, 01 Jan 1970 00:00:01 GMT
Set-Cookie: __cf_bm=bin10duidKdF6vN27ahHYxNqnw.NxagOfEHsoiMbMbM-1668373994-0-AWOI+udp/7x1
Strict-Transport-Security: max-age=2592000; includeSubDomains
X-Content-Type-Options: nosniff
Server: cloudflare
CF-RAY: 769a8286dd543b9a-BOS
```

There is actually an easier way to do this. The website netcraft.com will give hosting history for websites. This will provide the owner of the network block that contains the IP address. It will also tell you the operating system the web server runs on. In some cases, you will get details about the web server version and other modules that have been enabled. One of the domains I have has been around for a long time, and [Figure 4.15](#) shows the hosting history for that domain. In 2001, the site was hosted on an OpenBSD system (Netcraft says NetBSD/OpenBSD, but since I was hosting it myself, I know it was OpenBSD). You can also see that it was running on Apache at that time. This is an older hosting history from Netcraft. The current report only shows a single hosting provider in the history listing, but the output also shows a lot of other details, including whether the site is vulnerable to attacks like POODLE or Heartbleed.

Hosting History					
Netblock owner	IP address	OS	Web server	Last seen	Refresh
Microsoft Corporation One Microsoft Way Redmond WA US 98052	40.108.146.42	Windows Server 2012	Microsoft-IIS/8.5	31-Jan-2017	
Microsoft Corporation 1 Microsoft Way Redmond WA US 98052	104.146.136.50	Windows Server 2012	Microsoft-IIS/8.5	25-Jan-2017	
Microsoft Corporation One Microsoft Way Redmond WA US 98052	157.55.152.140	unknown	Microsoft-IIS/7.5	3-Feb-2014	
Comcast Cable Communications, LLC 1800 Bishops Gate Blvd Mt Laurel NJ US 08054	173.162.202.18	Linux	Apache	30-Mar-2010	
Mesa Networks Frederick CO US 80516	66.227.89.225	Linux	Apache	18-Sep-2007	
HostMySite 650 Pencader Drive Newark DE US 19702	66.241.216.11	Linux	Apache/1.3.29 Unix mod_ssl/2.8.16 OpenSSL/0.9.6c PHP/4.3.3 FrontPage/5.0.2.2623	9-Jun-2004	
LNI Inc. 260 Chapman Road, Suit 205 Newark DE 19702 US	66.241.216.11	Linux	Apache/1.3.27 Unix PHP/4.2.3 mod_ssl/2.8.12 OpenSSL/0.9.6b FrontPage/5.0.2.2510	20-Mar-2003	
Speakeasy Network 2304 2nd Ave Seattle, WA 98121 US	66.92.79.131	-	Apache/1.3.19 Unix PHP/4.0.4pl1 mod_ssl/2.8.2 OpenSSL/0.9.6	1-Sep-2001	
Speakeasy Network 2304 2nd Ave Seattle, WA 98121 US	66.92.79.131	NetBSD/OpenBSD	Apache/1.3.19 Unix mod_ssl/2.8.2 OpenSSL/0.9.6	30-Aug-2001	

FIGURE 4.15 Netcraft hosting history

While the history is interesting, it's far more relevant to know what the technology for the website is now. The top line is the most recent. Currently, the site is hosted on IIS with the network block being owned by Microsoft. That suggests that Microsoft is hosting this site, and since it's IIS, the operating system would be Windows Server. What we don't know is what version of Windows Server. The reason this information is useful is that we may be able to get a leg up on vulnerabilities. If we have some hints about versions, we would have a much better idea what vulnerabilities exist on the system where the website is hosted.

This only gives us the operating system and the web server. These days there is far more technology being used in websites. Static pages are written in HTML, but it's far more likely that you'll be running up against a dynamic site. This means you may find a site written in the PHP or Java programming language. The language itself isn't enough to provide the deep functionality needed by a robust web application. Instead, website programmers are apt to use frameworks. The frameworks can have vulnerabilities, as exhibited by the Experian data breach, which used a vulnerability in the Spring framework used by Java-based applications.

Back to the land of web browser plugins we go. One that is really good is Wappalyzer. Wappalyzer can be added to both Chrome and Firefox. When you visit a website, Wappalyzer will provide a list of technologies it identifies. This may include the web server, programming frameworks, ad networks, and tracking technology. It's not always successful in identifying everything. Going to www.google.com turns up the Google web server and an analytics framework. However, visiting CNN turns up a lot of different technologies, some of which you can see in [Figure 4.16](#). What we don't get there is the web server being used by CNN. We will take what we get, though, considering all the other technologies in use on the site.

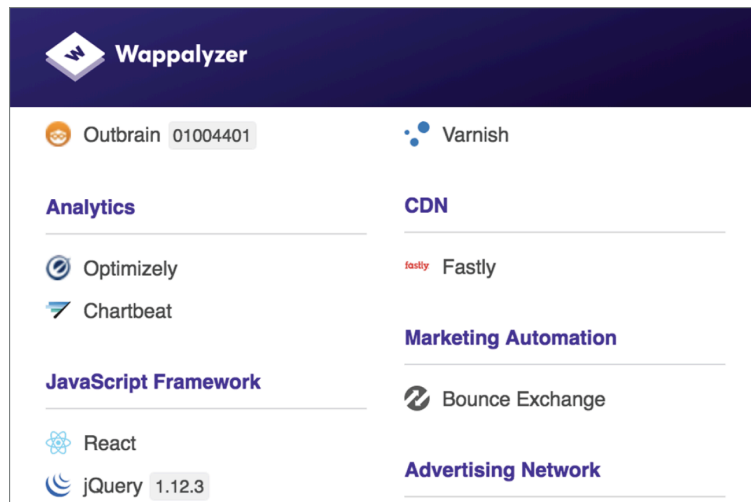


FIGURE 4.16 Wappalyzer for technology

There are other ways you can dig into web pages and the technologies used. One of them is Firebug. It's available on Firefox, though there is also Firebug Lite that's available in Chrome. Firebug Lite doesn't have quite the same capabilities as the full Firebug. However, on Chrome, Google has provided the developer tools. Using either the Chrome developer tools or Firebug, you can perform a deep investigation of the page you are looking at. To begin with, you can look at the Document Object Model (DOM) and all of its components. You can also select different HTML elements in the page and identify styles and properties applicable to that section. [Figure 4.17](#) shows a portion of the information that you can get using the Chrome developer tools. The page being inspected here is a Google search page. Using a tool like this, you can get a better understanding of how the page operates by looking at all the elements of the page and how they relate to one another.

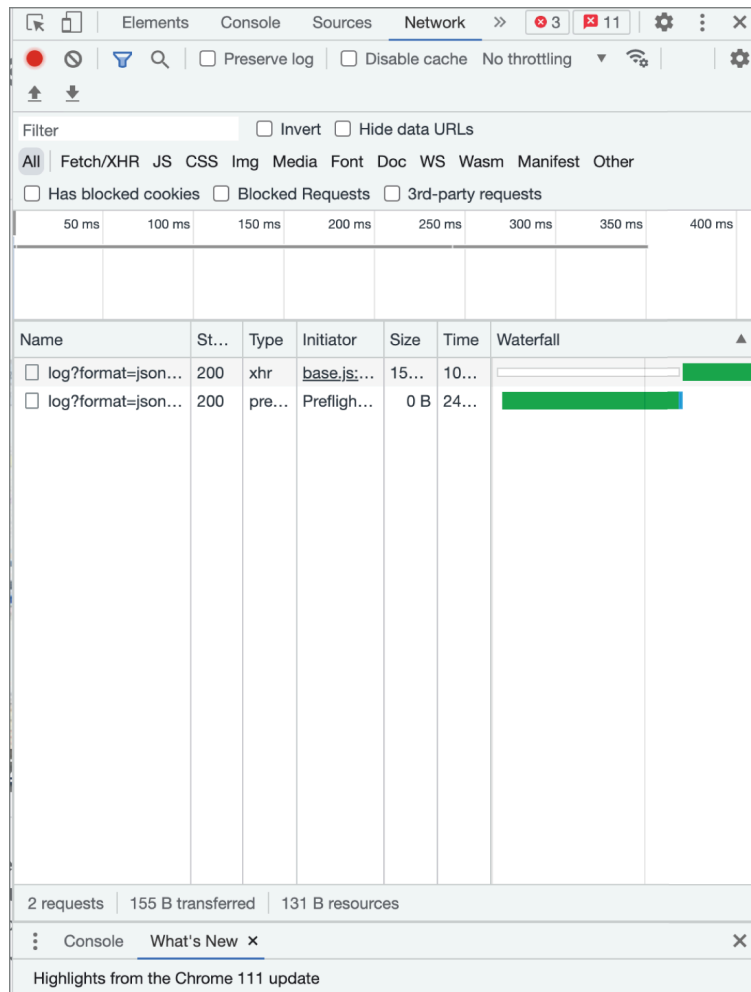


FIGURE 4.17 Chrome developer tools

Websites are complex creatures. The Chrome developer tools and Firebug are capable of looking at only a page at a time. You'd have to dig through every page, one at a time, to investigate them and their capabilities. You may find it easier to mirror the website so you could look at it offline. With it stored locally, you could look at the pages as many times as you would like without needing to issue repeated requests to the remote server. While the requests aren't likely to raise any eyebrows and aren't even likely to be noticed, you are leaving tracks behind. One tool you can use to mirror the website is HTTrack. In the following code, you can see the results of running HTTrack to mirror a website. The program will essentially perform a spider on the remote site, storing the results in the directory provided.

Mirroring Sites with `httrack`

```
$ httrack
```

```
Welcome to HTTrack Website Copier (Offline Browser) 3.49-2+libhtsjava.so.2 Copyright (C)
To see the option list, enter a blank line or try httrack --help
```

```
Enter project name :MySite
```

```
Base path (return=/root/websites/) :
```

```

Enter URLs (separated by commas or blank spaces) :http://www.domain.com

Action:
(enter)   1   Mirror Website(s)
          2   Mirror Website(s) with Wizard
          3   Just Get Files Indicated
          4   Mirror ALL links in URLs (Multiple Mirror)
          5   Test Links In URLs (Bookmark Test)
          0   Quit
: 1

Proxy (return=none) :

You can define wildcards, like: -*.gif +www.*.com/*.zip -*img_*.zip
Wildcards (return=none) :

You can define additional options, such as recurse level (-r<number>),
separated by blank spaces
To see the option list, type help
Additional options (return=none) :

```

Once you have the HTML, you can do anything you want with it. You can make changes, review all the scripts that are included in the pages, and review the pages as you need to. Not all technology is in the website, though. Organizations have a lot of other technology that can generally be mined using a variety of tools and techniques.

Technology Intelligence

Ultimately, your goal as an ethical hacker is to identify vulnerabilities within the organization you are working for. While web interfaces are an attractive place to play and look for vulnerabilities, considering how much sensitive data can be available through web interfaces, it's not the only place to look for vulnerabilities. However, you can still make use of websites to continue to explore the bounds of technology within your target company. So far, we've identified job sites and some social networking sites in order to gain intelligence about technology in use at a target. Beyond that, we can look at a couple of other areas. The first is to help really focus our web searches using Google dorks, also known as Google hacking. Additionally, we can look for devices that are part of the so-called Internet of Things (IoT).

Google Hacking

Google hacking is an important skill to have. It will improve the search responses, saving you a lot of time clicking through pages that aren't especially valuable. Once you know some of the keywords that can be used to really narrow your searches, you'll save time and become more efficient. The Google hacking techniques will help you to identify technology and vulnerabilities. In addition to Google hacking techniques, there is the Google hacking database, which is a collection of Google dorks that have been identified by someone as a way to search for a number of things. A dork is a string using Google keywords, designed to search for useful responses.

First, the Google keywords. If you've been using search engines for a long time, you may be familiar with the use of quotation marks and Boolean terms to help ensure that you are getting the right strings in your responses. In addition to those, Google uses positional keywords. You may, for instance, want to look only in the URL for a particular string. To search in the URL, you would use `inurl` as in the example, `inurl:index`. This example would find pages that included the word `index` anywhere in the URL. This might typically be a page like `index.html`, `index.php`, or `index.jsp`. If you wanted to ignore the URL and only search in the text, you could use the keyword `intext`.

Since you are working for an organization, you have one domain or maybe a small handful of domains. This means you will, at some point, want to search only within those domains. To do that, you can use the `site` keyword. You may also want to limit your results to a single filetype, such as a portable document format (PDF) file or a spreadsheet. To limit your results to just one filetype, you would use the `filetype` keyword. Perhaps you are looking for all PDF documents about Windows 11 on Microsoft's site. [Figure 4.18](#) shows the search used for that (site: [Microsoft.com](#) filetype:pdf "Windows 11") as well as a number of results.

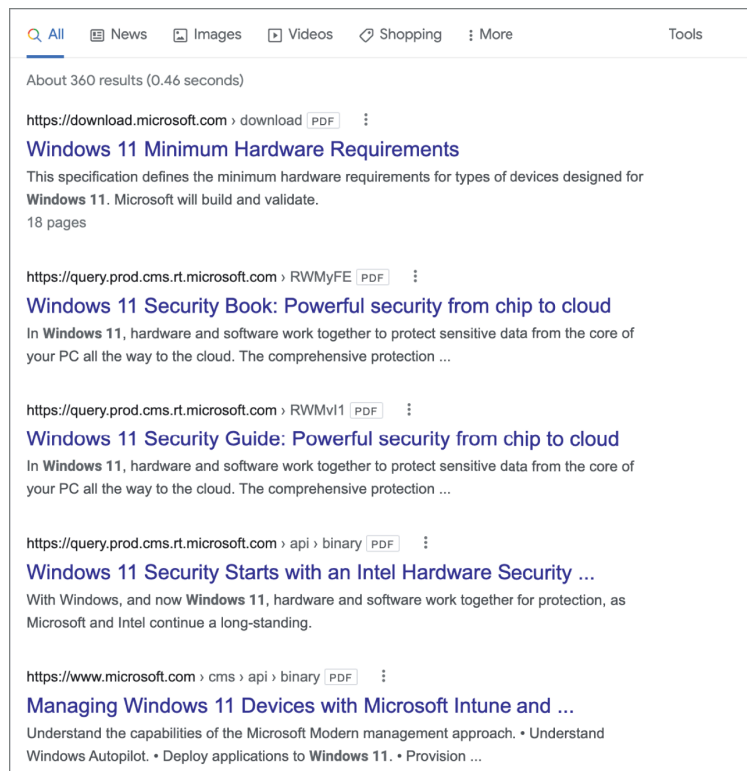


FIGURE 4.18 Google hacking results

A great place to look for examples of useful Google dorks is the Google Hacking Database (<https://www.exploit-db.com/google-hacking-database/>). The Google Hacking Database (GHDB) stores search terms in several categories, including footholds, vulnerable files, error messages, and sensitive directories. Creating these useful search strings requires that you know not only about the Google hacking keywords but also about what you are looking for. Some examples are in [Figure 4.19](#), where the

search strings are looking for network or vulnerability data. This means that someone would have had to know exactly what would be in a page or URL that would include this data. [Figure 4.19](#) shows some of these.

Google Hacking Database

FiltersReset All

Show 15Quick Search

Date Added	Dork	Category	Author
2022-09-19	intext:"index of" "sql"	Files Containing Juicy Info	Gopalasmy Rajendran
2022-09-19	intitle:"index of" inurl:superadmin	Files Containing Juicy Info	Mahedi Hassan
2022-09-19	intitle:"WAMP/SERVER Homepage"	Files Containing Juicy Info	HackerFrenzy
2022-09-19	inurl:json beautifier online	Files Containing Juicy Info	Nyein Chan Aung
2022-09-19	intitle:"IS Windows Server"	Files Containing Juicy Info	HackerFrenzy
2022-09-19	intitle:"index of" inurl:SUID	Files Containing Juicy Info	Mahedi Hassan
2022-09-19	intitle:"index of" intext:"Apache/2.2.3"	Files Containing Juicy Info	Wagner Farias
2022-08-18	inurl:"index.php?page=news.php"	Advisories and Vulnerabilities	Omar Shash
2022-08-18	inurl:/sym404root	Files Containing Juicy Info	Numen Blog
2022-08-17	inurl:viewer/live/index.html	Various Online Devices	Palvinder Singh Secunews
2022-08-17	intitle:index of "view"	Sensitive Directories	Abhishek Singh
2022-08-17	intitle:"WEB SERVICE" "wan" "lan" "alarm"	Pages Containing Login Portals	Hevenin Hacker
2022-08-17	allintitle:"Log on to MACH ProWeb"	Pages Containing Login Portals	Under The Sea hacker
2022-08-17	intitle:"index of" "access_token.json"	Files Containing Juicy Info	Leonardo Venegas
2022-08-17	inurl:"admin/default.aspx"	Pages Containing Login Portals	Payal Yedhu

FIGURE 4.19 Google Hacking Database

Spending time at the GHDB can provide you with a lot of ammunition for looking for possible issues within your target. Some of this will be blind, if you have no idea what to expect within your target. To make sure you are only searching within your target, of course, you would need to add site: and the domain name to your search parameters. One thing you may have noticed from the Microsoft search in [Figure 4.19](#) is that when only the domain was used, every possible hostname came back. If you want to search only within a single FQDN, such as [www.microsoft.com](#) , you would provide the FQDN. Only providing the domain will be another way to catch additional FQDNs that you may not have been able to get using DNS searching.

Internet of Things (IoT)

You will likely have heard about the IoT. The IoT is made up of devices that may have little to no input or output capabilities, at least from a traditional standpoint. If a device can run general applications and also has a keyboard and a screen, such as a computer, tablet, or smartphone, it's not part of the IoT. Many other devices, like network-connected thermostats, light bulbs, fans, refrigerators, and a number of other essentially single-purpose devices, are IoT devices. Many companies are making use of this in different automation capacities.

These devices can be useful when it comes to infiltrating a system. Malware like Satori can infect multiple IoT devices, and once infected, those devices can be used to attack other systems. They may also be good starting points into the enterprise network, depending on the device. This is another area where search engines, though, can be helpful to us. Shodan ([www.shodan.io](#)) is a search engine specifically for IoT devices. Shodan keeps track of a large number of devices along with vendors, device types, and capabilities.

Shodan also requires understanding your target and what can be used to identify these devices. [Figure 4.20](#) shows an example. The search term is *port:20000 source address*, which identifies Distributed Network Protocol (DNP) 3 devices. This is another area where the site can be a lot of help.

The search for DNP3 devices came as a result of clicking a link for Industrial Control Systems (ICSs) and looking at different protocols that Shodan knows about. Shodan also associates with ICS the Factory Interface Network Service (FINS), Highway Addressable Remote Transducer Protocol, and many others. There are also searches for different vendors.

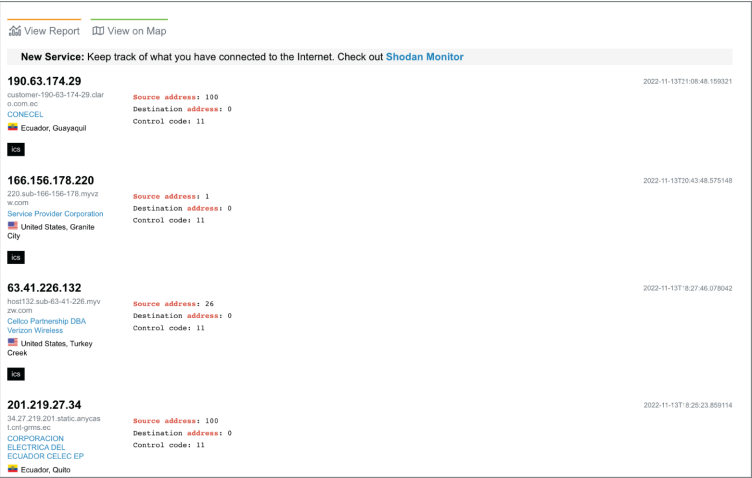


FIGURE 4.20 Shodan search for DNP3

On the left of the search results, not shown in that image, is a map with a count of the devices by country. Figure 4.21 shows the map and the count of devices by country. One thing you may notice in the statistics is the fact that the United States is on top of all countries with these devices. Shodan also identifies organizations where the devices are located. Clicking individual results provides more details, including where the device is located.

Shodan is an excellent resource when it comes to identifying devices that are considered part of the IoT. Using searches of the Shodan database, you can identify devices that may exist on the target network.

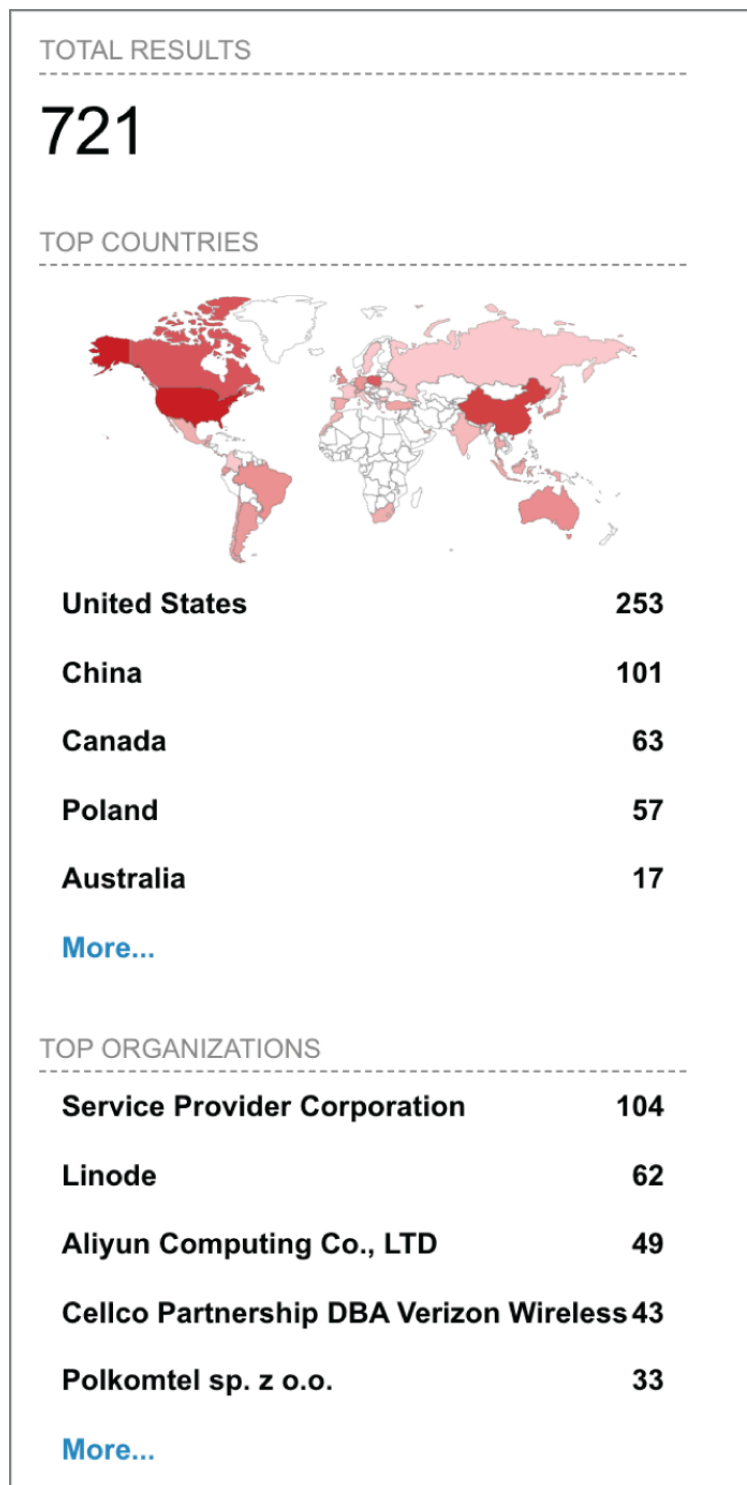


FIGURE 4.21 Shodan results

Summary

Footprinting and reconnaissance are important activities in an overall methodology when it comes to ethical hacking. This is the stage where you collect a lot of data that you will use later. It's also a stage where you don't want to make a lot of noise. You're sneaking up on someone to scare them. If you make noise, you get no startled reaction from your target. The same is true here. You want to do your work ahead of time so when you get started, you aren't registering a lot of activity that could get you detected and the next thing you know, you've been locked out.

If you are interested to see techniques, tactics, and procedures we know real-life attackers used, you can refer to the MITRE ATT&CK framework and get some ideas of how those attackers may operate. This can help you ensure you are providing a full set of testing to the organization you are working with.

There are multiple sources of intelligence that are freely and openly available. Using sources like the SEC's EDGAR database, you can obtain information about companies. Job sites can also provide you with details about a company that may be useful later. This includes the technology they may be using, since when they hire people, they generally provide job requirements, including technology vendors like Microsoft, Red Hat, Cisco, and Palo Alto Networks. You can also read reviews from employees that may have useful data.

Social network sites can be used to gather information about people, as well as companies. The people sometimes post information about their jobs or the company in general. Social engineering is a common attack technique, and this attack technique can be more successful if you know how to target individuals. You can also gather information about the companies themselves. Often, companies will have a social network presence. Additionally, there are sites like LinkedIn that are focused on businesses and business interactions.

The Internet requires data to function. This includes who has been allocated addresses. These allocations go through RIRs. You can use tools like `whois` to gather some of this data from the RIRs. The program `whois` can also be used to gather registration details about domains. This would include addresses, phone numbers, and contact information. Not all domains will have this information since registrars will sometimes hide the details of the registrant. What you'll get is the registrar's contact information and address and not the organization. What you will also get out of this is the registered NSs for the domain. These are the NSs considered to be authoritative for the domain.

DNS contains a lot of detail about a company if you can find it. The quickest way to get all of the hosts is to do a zone transfer, but it would be unlikely for zone transfers to be allowed. Instead, you may have to resort to something like brute-forcing DNS requests to guess possible FQDNs. From this, you will get FQDNs that can become targets. You will also get IP addresses. These IP addresses can be run through `whois` to get the network block and the owner of the block. You may get ranges of IP addresses that belong to the company from doing that.

It's a common tactic for companies to have both internal and external DNS servers. This helps protect the company by not exposing internal systems to the outside world. Once you have access to the inside of the network by compromising some system, you can look at the DNS cache. This is done on Windows systems by running `ipconfig /displaydns`. This will show all of the cached DNS entries, meaning FQDN/IP mappings that were resolved at some point and are being stored to help speed up the resolution the next time an application needs the IP address. A cached en-

try will mean a network request doesn't have to be made, which can save time.

Many attacks take place through web interfaces. While gathering details about a web server or the technologies used in a website isn't entirely passive, meaning using third-party sources, making common requests to a web server shouldn't be noticed much. As long as you aren't sending too many requests all at once or sending something unusual, you'll get lost in the noise of all the other regular requests.

Google hacking is a technique you can use to narrow your search and get results that are focused and relevant. Google hacking is a technique that makes use of keywords like *site*, *inurl*, *intext*, *filetype*, and *link* to get very specific results. One of the most useful will be the *site* keyword, which means you are searching within only one domain. This means you are only looking at results within the organization you are testing for. If you need help identifying search terms that may help you identify vulnerabilities, you can use the Google Hacking Database.

People and businesses are often using devices that have a network connection but don't have traditional means for users to interact with them. This often means these devices can be vulnerable to attack. All these devices are called the Internet of Things (IoT). There are sites like Shodan that can be used to identify these embedded devices. Shodan will provide a lot of details about a device, including the IP address and where the IP address is located. You should be able to narrow down whether the device belongs to your target company using a site like Shodan.

Review Questions

You can find the answers in the appendix.

1. If you were checking on the IP addresses for a company in France, what RIR would you be checking with for details?
 - A. ARIN
 - B. RIPE
 - C. AfriNIC
 - D. LACNIC
2. You need to identify all Excel spreadsheets available from the company Example, Inc., whose domain is [example.com](#). What search query would you use?
 - A. *site: [example.com](#) files:pdf*
 - B. *site:excel files:xls*
 - C. *domain: [example.com](#) filetype:xls*
 - D. *site: [example.com](#) filetype:xls*
3. If you found a colleague searching at [pgp.mit.edu](#), what would they likely be looking for?
 - A. Email addresses
 - B. Company keys
 - C. Executive names
 - D. Privacy policies
4. What information could you get from running `p0f`?

- A. Local time
 - B. Remote time
 - C. Absolute time
 - D. Uptime
5. The DNS server where records for a domain belonging to an organization or enterprise reside is called the _____ server.
- A. Caching
 - B. Recursive
 - C. Authoritative
 - D. Local
6. What strategy does a local, caching DNS server use to look up records when asked?
- A. Recursive
 - B. Serial
 - C. Combinatorics
 - D. Bistromathics
7. What would you use a job listing for when performing reconnaissance?
- A. Executive staff
 - B. Technologies used
 - C. Phishing targets
 - D. Financial records
8. What tool could be used to gather email addresses from Bing, Google, and other sources?
- A. whois
 - B. dig
 - C. netstat
 - D. theHarvester
9. What social networking site would be most likely to be useful in gathering information about a company, including job titles?
- A. Twitter
 - B. LinkedIn
 - C. Foursquare
 - D. Facebook
10. You see the following text written down—port:502. What does that likely reference?
- A. Shodan search
 - B. I/O search
 - C. p0f results
 - D. RIR query
11. What would you use Wappalyzer for?
- A. Analyzing web headers
 - B. Analyzing application code
 - C. Identifying web headers
 - D. Identifying web technologies
12. What technique would you ideally use to get all the hostnames associated with a domain?
- A. DNS query
 - B. Zone copy
 - C. Zone transfer
 - D. Recursive request

13. What information would you not expect to find in the response to a `whois` query about an IP address?
- A. IP address block
 - B. Domain association
 - C. Address block owner
 - D. Technical contact
14. What would you be looking for with the `filetype:txt Administrator:500:` Google query?
- A. Text files owned by the administrator
 - B. Administrator login from file
 - C. Text files including the text `Administrator:500:`
 - D. 500 administrator files with text
15. What command would you use to get the list of mail servers for a domain?
- A. `whois mx zone= domain.com`
 - B. `netstat zone= domain.com mx`
 - C. `dig domain.com @mx`
 - D. `dig mx domain.com`
16. What would you get from running the command `dig ns domain.com`?
- A. Mail exchanger records for `domain.com`
 - B. Name server records for `domain.com`
 - C. Caching name server for `domain.com`
 - D. IP address for the hostname `ns`
17. If you wanted to locate detailed information about a person using either their name or a username you have, which website would you use?
- A. `peekyou.com`
 - B. `twitter.com`
 - C. `intelius.com`
 - D. `facebook.com`
18. If you were looking for detailed financial information on a target company, with what resource would you have the most success?
- A. LinkedIn
 - B. Facebook
 - C. EDGAR
 - D. MORTIMER
19. What financial filing is required for public companies and would provide you with the annual report?
- A. 10-Q
 - B. 11-K
 - C. 401(k)
 - D. 14A
20. If you were looking up information about a company in New Zealand, which RIR would you be looking in for data?
- A. AfriNIC
 - B. RIPE
 - C. APNIC
 - D. LACNIC
21. What record would you use to identify a name server associated with a specific domain?
- A. TXT

- B. MX
 - C. NS
 - D. PTR
22. What would you use the website PeekYou for?
- A. DNS lookup
 - B. Person search
 - C. Identifying domain registrars
 - D. Identifying IoT devices
23. The following performs two DNS queries. What two records are referenced in this query response?

```
host www.wiley.com
www.wiley.com is an alias for
www.wiley.com.cdn.cloudflare.net.
www.wiley.com.cdn.cloudflare.net has address 104.18.17.99
```

- A. CNAME, A
 - B. CNAME, PTR
 - C. A, PTR
 - D. PTR, MX
24. What are you looking for with the following Google dork, or Google query? site: pastebin.com intext:password.txt
- A. Pasted passwords
 - B. Binary data for a password program
 - C. A file of passwords on a common storage website
 - D. Plaintext usernames and passwords
25. What would you use the tool Sherlock for?
- A. Searching for fingerprints
 - B. Looking up job information
 - C. Looking for potential usernames
 - D. Searching domain registrars

Table of contents collapsed